



02 EKİM 2026

YÖNETİM + TEKNİK EKİP

Uygulama yayına ne kadar hazır?

DOSSO DOSSI COFFEE

Mobil uygulama, backend ve admin paneli için
güvenlik, işleyiş ve üretim hazırlığı raporu.

KARAR

**Gerçek para ve müşterilerle genel yayına hazır
değil.**

Temel ürün ve test altyapısı var. Ödeme entegrasyonu, finansal tutarlılık, erişim sınırları ve yayın
operasyonları tamamlanmalı.

İncelenen sürüm: berkay-branch / d3cfc34

Çalışma biçimi: Kaynak kod değiştirilmeden, ayrı test veritabanıyla inceleme.

Yönetici özeti

Uygulama kapsamlı bir ürün temeline sahip. Ekranların çalışması ile gerçek müşteriye güvenle hizmet vermek aynı olgunluk aşaması değil.

Şu anki karar: genel yayını beklet

Gerçek ödeme alan veya gerçek müşteri bakiyesi yöneten açılış önerilmiyor. Demo ve iç değerlendirme sürdürülebilir. Sınırlı pilot için dahi aşağıdaki kritik para, yetki ve entegrasyon kontrolleri kapatılmalı.

Güçlü temel

Modüler mobil yapı, API katmanı, yönetim paneli, güvenli token deposu ve geçen temel testler mevcut.

Asıl açık

Ödeme/POS/SMS bağlantıları ve bazı eşzamanlı para işlemleri üretim güvenilirliğinde değil.

Doğru yaklaşım

Uygulamayı yeniden yazmak gerekmiyor. Mevcut servis ve ekranları küçük, kontrollü adımlarla sağlamlaştırmak yeterli.

ÖNCE BU BEŞ BAŞLIK

Öncelik	Yönetim açısından anlamı
1. Gerçek ödeme	Banka onayı alınmadan bakiye artmamalı; test sağlayıcısı üretimde açılmamalı.
2. Tek işlem, tek sonuç	Çift dokunma, ağ tekrarı ve paralel istek fazla tahsilat/ikram/iade üretmemeli.
3. Doğru erişim	Şube yöneticisi yalnız yetkili olduğu veriyi görmeli; bloklama gerçekten işlem durdurmalı.
4. Doğru fiyat ve durum	Müşterinin onayladığı tutar, tahsil edilen tutar ve kasadaki sipariş durumu tutarlı olmalı.
5. Güvenli yayın	Gerçek sağlayıcı sandbox testleri, imzalı release, yedekten dönüş ve izleme kanıtı tamamlanmalı.

Bu rapor uygulamayı bozacak bir değişiklik yapmadı. Bulgular düzeltme önerisidir; hiçbir özellik kapatılmadı ve mevcut işletme verisinde işlem yapılmadı.

Okuma rotası: Yönetim için ilk 8 sayfa; teknik bulgular 9. sayfadan itibaren; yol haritası 43, yayın kontrol listesi 45, bulgu dizini 48. sayfada. PDF yer imleriyle bölümlere doğrudan geçebilirsiniz.

Neyi inceledik, neyi doğrulamadık?

Rapor 02.10.2026 tarihindeki d3cfc34 commit'ine aittir. Başka bir dal veya sonraki değişiklikler için sonuçlar yeniden doğrulanmalıdır.

İnceleme alanı	Yapılan kontrol
Flutter mobil	Giriş/oturum, sepet ve fiyat, cüzdan/QR, ikram/hediye, profil, canlı yenileme, hata durumları ve native release ayarları.
Backend / PostgreSQL	Kimlik doğrulama, para ve ikram hareketleri, webhook, eşzamanlı istekler, idempotency, engelli hesaplar, sağlayıcılar ve iş kuralları.
React admin	Rol/şube kapsamı, oturum önbelleği, aktif sipariş panosu, menü/ayar sözleşmeleri, finans/CSV/XLSX ve derleme.
Yayın / operasyon	Paket güvenlik taraması, başlatma ayarları, depo içi CI/deploy/yedek/izleme kanıtı, geliştirme ve üretim sınırları.

Güvenli denetim sınırı

Mevcut uygulama kaynakları, .env dosyaları ve çalışan dosso_dossi veritabanı değiştirilmedi. Finansal senaryolar ayrı PostgreSQL 17 container'ı ve ayrı porttaki test verisiyle çalıştırıldı. Admin smoke testi veri değiştirdiği için canlıda çalıştırılmadı.

KANIT DÜZEYLERİ

İşaret	Anlamı
İzole DB testi	Gerçek servis/HTTP kodu, ayrı test veritabanı ile beklenen kusuru tekrar üretti.
İzole bellek / Flutter	Sahte adaptör veya bellek verisiyle ilgili kod davranışı doğrulandı; tüm uygulamanın canlı uçtan uca testi değildir.
Statik kanıt	Kod yolu ve yapılandırma incelendi; canlıda istismar veya gerçek ödeme denenmedi.
Kanıt yok / ölçülmedi	Depoda ya da erişilen ortamda gösterilemedi; harici sistemin kesinlikle bulunmadığı anlamına gelmez.

Kapsam dışı: dış ağdan sızma testi, gerçek banka/Kerzz/SMS işlemi, gerçek cihaz mağaza sürümü, yoğun yük testi, harici sunucu/sertifika ve mağaza hesaplarının denetimi. Bu çalışma güvenlik sertifikası veya hukuki uygunluk onayı değildir.

Hazırlık haritası

Yüzdelik bir puan yerine, her alanın yayına çıkış kararına etkisi ayrı gösterildi.

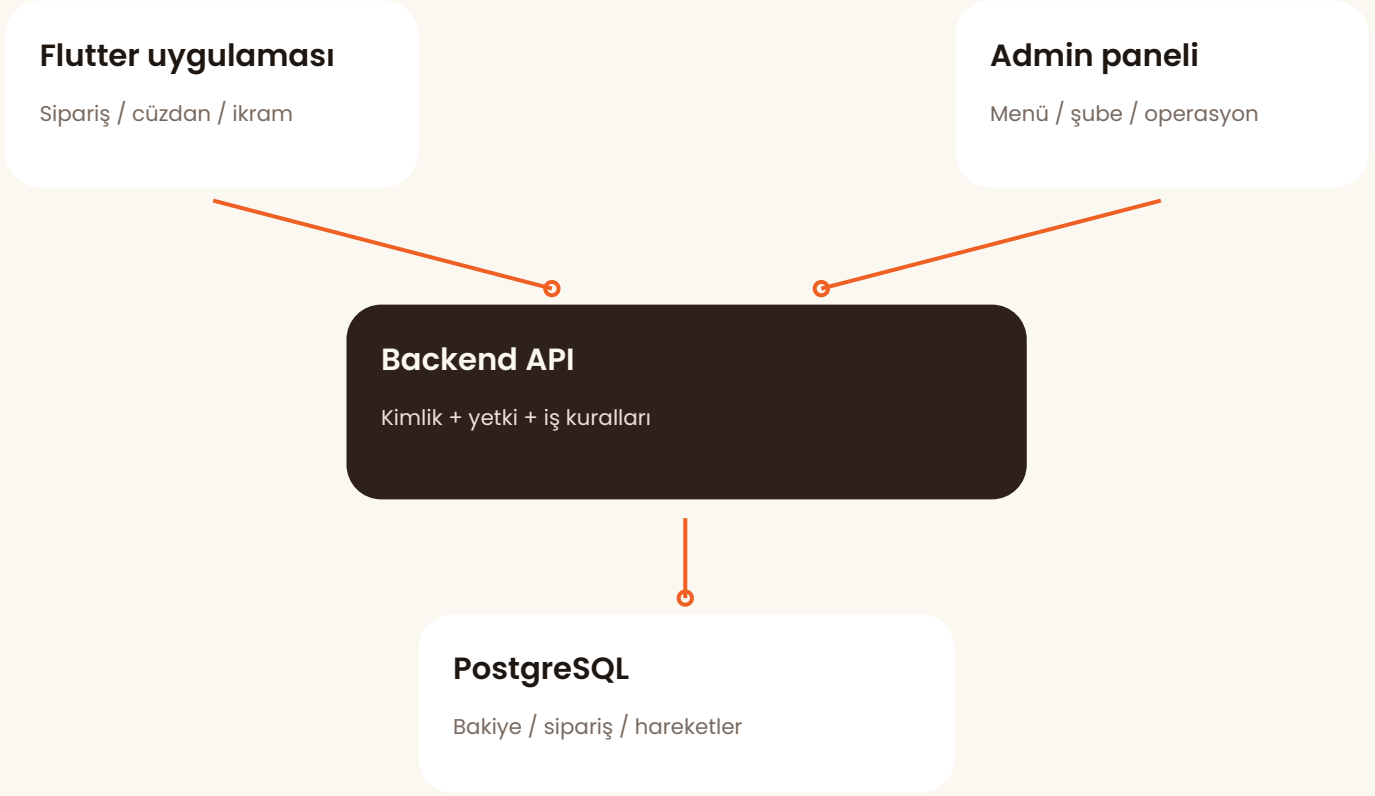
Alan	Durum	Neden
Ürün ve arayüz kapsamı	GÜÇLÜ TEMEL	Sipariş, cüzdan, sadakat, hediye, mağazalar ve panel modülleri var.
Temel otomatik kontroller	OLUMLU	29 mobil ve 143 backend regresyon testi geçti; derleme/analiz kontrolleri çalıştı.
Ödeme / POS / SMS	YAYINI ENGELLER	Gerçek sağlayıcılar tamamlanmamış; geliştirme davranışı üretimde engellenmiyor.
Para ve ikram tutarlılığı	YAYINI ENGELLER	Eşzamanlı işlemler, tekrar gönderim ve kuruş hassasiyeti kusurları doğrulandı.
Yetki ve hesap sınırları	YAYINI ENGELLER	Şube kapsamı, engelli kullanıcı ve oturum önbelleği açıkları var.
Mobil hata dayanıklılığı	İYİLEŞTİRİLMELİ	Auth retry kilitlenmesi, eski QR ve oturumlar arası sepet/lifecycle sorunları var.
Admin operasyon güveni	İYİLEŞTİRİLMELİ	Aktif sipariş görünümü, bazı ayarlar ve dışa aktarımlar eksik/yanıltıcı sonuç verebilir.
Release / kurtarma / yük	KANIT BEKLİYOR	Release yapılandırma kusurları var; gerçek deploy, restore ve yük doğrulaması yapılmadı.

Geçen testler neden tek başına yeterli değil?

Mevcut testler yazıldıkları normal ve hata senaryolarını doğruluyor. Bu denetimde eklenen paralel işlem, hesap değiştirme ve bozuk ağ senaryoları farklı sınırları test etti. Aynı kod tabanında normal akışların geçmesi ve ciddi kenar durum hatalarının bulunması mümkündür.

Çalışan yapı ve kritik sınırlar

Korunması gereken ana mimari: ekranlar -> servisler -> tek iş kuralı ve kayıt kaynağı.



Dış bağlantı	Mevcut durum	Üretim için gerekli
Ödeme sağlayıcısı	DevPaymentProvider	Gerçek tahsilat, doğrulama, pending/3DS, başarısızlık ve iade.
Kerzz POS	Geliştirme adaptörü	Şubeye gerçek gönderim, tekrar güvenliği, iptal/iade ve mutabakat.
SMS / push	SMS dev, push eksik	OTP teslimi, bildirim kuyruğu, teslim/tekrar izleme.
Yayın ortamı	Yerel geliştirme	TLS, secret yönetimi, release imzası, yedek ve alarm.

Servis/repository ayrımları bu tamamlamaları destekliyor. Öneri, tasarımları veya ana navigasyonu yeniden kurmak değil; mevcut sınırların arkasındaki doğrulama ve işlem kurallarını güçlendirmek.

Test sonuçları ve kanıt özeti

Kontroller canlı müşteriye, bakiyeye veya siparişe dokunmadan yapıldı.



29 / 29

Flutter testleri geçti. Analiz:
sorun yok.



143 / 143

Backend mevcut testleri geçti.
16 test dosyası.



14 senaryo

Ek backend denetimleri kusurlu
davranışları yeniden üretti.

Kontrol	Sonuç	Yorum
flutter analyze --no-pub	GEÇTİ	Derleyici/lint temiz; iş akışının doğru olduğunu tek başına kanıtlamaz.
flutter test / mock mod	29 GEÇTİ	Gerçek ödeme, SMS veya POS bağlantısı test edilmedi.
Backend typecheck + test	143 GEÇTİ	Ayrı PostgreSQL ortamı; çalışan DB kullanılmadı.
Admin typecheck / build / lint	GEÇTİ	5 lint uyarısı ve yaklaşık 724 kB tek JS parçası uyarısı var.
Ek mobil prob	HATALAR DOĞRULANDI	Auth retry kuyruğu; çıkış sonrası sepet; dispose sonrası timer.
Ek admin bellek problemleri	HATALAR DOĞRULANDI	Hesaplar arası cache, export sınırı/formülü/filtre ve ayar doğrulaması.
Yerel servis sağlık kontrolü	HTTP 200	API /health ve panel erişilebilir. Bu bir üretim kapasite testi değil.

14 denetim senaryosunun “geçmesi” ne demek?

Bu senaryolar mevcut hatayı görünür kılmak için yazıldı. Örneğin ikinci iadenin oluştuğu veya bakiyenin negatif kaldığı sonuç doğrulandı. Güvenli davranışın onaylandığı anlamına gelmez. Düzeltme sırasında bunlar doğru sonucu bekleyen regresyon testlerine çevrilmeli.

Para ve ikramda ölçülen farklar

Tamamı ayrı test verisiyle üretildi. Aşağıdaki tutarlar gerçek müşteri hesabından alınmadı.

Senaryo	Güvenli sonuç	Gözlenen sonuç
1.000 TL bakiye, 190 TL sipariş, iki paralel iptal	1.000 TL / 1 iade	1.190 TL / 2 iade
1 ikramla iki paralel ücretsiz sipariş	En fazla 1 ücretsiz sipariş	2 ücretsiz sipariş / hak -1
İki farklı ilk yükleme aynı anda onaylanır	Toplam 5 bonus kahve	Toplam 10 bonus kahve
İki ayrı sadakat kazanımı aynı anda	2 damga	1 damga / 2 olay kaydı
100 TL bakiyeye iki adet -80 TL düzeltme	Biri reddedilir / 20 TL	İkisi kabul / -60 TL
190 TL siparişi POS iptal eder	Bakiye 1.000 TL'ye döner	810 TL'de kalır
0,005 TL hediye tutarı gönderilir	Ret veya tek yuvarlama kuralı	0 TL düşüm / 0,01 TL hediye
Aynı sipariş isteği yeniden gönderilir	Aynı işlem anahtarında tek sipariş	2 sipariş / 2 tahsilat

Ortak kök neden

Bir işlemin transaction içinde olması tek başına yeterli değil. Bazı yollar önce değeri okuyor, sonra koşulsuz yazıyor. İki istek aynı eski değeri gördüğünde ikisi de geçebiliyor. Atomik koşullu güncelleme, tutarlı kilit sırası ve benzersiz işlem kaydı birlikte kullanılmalı.

Eşzamanlı testlerde okuma adımlarını aynı ana getiren test bariyerleri kullanıldı. Gerçek PostgreSQL işlemleri çalıştı; bu, olası hatalı sıralamayı kanıtlar. Gerçek hayatta ne sıklıkta olacağını ölçmez.

Kontrol yaklaşımı: para ve haklar sunucuda yeniden doğrulanmalı; işlem geçişleri açık durum kuralları ve tekrar güvenliğiyle korunmalı. [S1, S2]

Korunacak güçlü taraflar

Bunlar sıfırdan yazılacak bir proje değil, güçlendirilecek mevcut bir sistem olduğunu gösteriyor.

Kontrol	Neyi koruyor?	Sınırı
Mobil secure storage	Oturum sırlarını sıradan yerel tercihlerden ayırıyor.	Oturum değişimindeki sepet/cache temizliğini tek başına sağlamaz.
Ayrı admin JWT + Argon2	Müşteri ve yönetici kimliklerini ayırıyor; parola hash'i var.	Global okuma uçlarında rol/şube kapsamı ayrıca gerekli.
HMAC + zaman penceresi	POS/ödeme webhook'unda imza ve tekrar zamanı kontrolü var.	İmzalı, geçerli bir olayın iş kuralını doğru uyguladığını garanti etmez.
PaymentIntent sahiplenme	Aynı ödeme onayı tekrarlanırsa aynı intent tek kredileniyor.	Farklı intent'lerde ilk yükleme bonusu yarışını engellemiyor.
QR / normal cüzdan düşümü	QR tüketimi ve normal harcama koşullu atomik kontrol kullanıyor.	Admin bakiye düzeltmesi ve sadakat farklı kod yolları.
Hediye claim koruması	Alıcı kimliği/telefonu ve tek kredileme kontrolü var; anonim bozdurma yok.	Seçilen ürünün uygunluğu ve bildirim başarısı ayrı sorunlar.
Audit + canlı revision	Panel değişiklikleri transaction ile audit'e yazılıyor; içerik değişince mobil yenileniyor.	İşlevsiz ayarı etkili yapmaz; müşteri/POS hareketleri aynı kapsamda değil.
Helmet / JSON sınırı / health	Temel HTTP sertleştirilmesi, küçük istek gövdesi ve DB sağlık kontrolü var.	Gerçek TLS, alarm, yedekten dönüş ve kapasite ayrıca doğrulanmalı.

Değişiklik ilkesi

Bu kontroller ve mevcut tema/navigasyon korunmalı. Kritik düzeltmeler, ilgili servislerin içine küçük ve testlenebilir adımlar halinde eklenmeli. Tek seferde framework, veri modeli veya tüm ödeme/sipariş ekranlarını değiştirmek gerekmiyor.

Backend: para, güvenlik ve iş kuralları

Her bulgu: gözlenen davranış, etkisi, en küçük güvenli düzeltme ve kapanış testi. B/ backend, M/ mobil, A/ admin kaynaklarını belirtir. Kod bağlantıları incelenen commit'e gider.

BE-01 | P0 / KRİTİK | STATİK KANIT

Üretimde de gerçek tahsilat olmadan bakiye üreten ödeme sağlayıcısı seçiliyor

paymentProvider koşulsuz new DevPaymentProvider(); createPayment her zaman succeeded döndürüyor. startTopUp bu cevabı confirmTopUp ile bakiyeye geçiriyor. Production env doğrulamasında ödeme sağlayıcısı engeli yok. Mevcut izole topup testleri simüle başarı/bakiye yazımını doğruladı.

İşletmeye etkisi: Gerçek kart tahsilatı/3DS olmadan PaymentIntent SUCCEEDED olur, harcanabilir cüzdan bakiyesi ve uygun ilk yükleme ikramı oluşur. Bu haliyle gerçek satış ortamı için yayın engelidir.

Yapıyı koruyan çözüm: Önce üretim başlangıcında dev/eksik sağlayıcı için fail-closed kontrol ekleyin; ödeme adaptörü seçim fabrikası ve doğrulanmış sağlayıcı entegrasyonu hazır olana kadar topup kapalı kalsın. Var olan geliştirme deneyimi yalnız development/test ortamında devam etsin.

Kabul kontrolü: Production+dev konfigürasyonu başlangıçta reddedilsin; sağlayıcıdan doğrulanmış başarılı tahsilat gelmeden bakiye değişmesin; aynı ödeme bildirimi 10 paralel tekrarında tek TOPUP yazılsın.

Kanıt: B/features/wallet/payments/dev-payment-provider.ts:8 · B/features/wallet/payments/topup.service.ts:26 · B/config/env.ts:19 · B/config/env.ts:47

BE-02 | P1 / YÜKSEK | STATİK KANIT

SMS sağlayıcısı geliştirme modunda sabit; OTP ve telefon loglanıyor

DevSmsProvider.send sadece logger.info yapıyor; export koşulsuz dev. OTP metni telefon ve altı haneli kod ile bu sağlayıcıya veriliyor.

İşletmeye etkisi: Kullanıcı gerçek SMS alamaz. Giriş OTP kodu ve alıcı telefonu uygulama loguna açık olarak yazılır; log erişimi olan kişiler geçerlilik süresinde OTP görebilir.

Yapıyı koruyan çözüm: Gerçek SMS adaptörü ve ortama göre provider seçimi; üretimde dev adaptörünü reddeden başlangıç kontrolü. OTP/telefonu loglardan kaldırın veya gerekli kimliği maskeleyin; gönderim durumu ve korelasyon kimliği yeterli olsun.

Kabul kontrolü: Üretim testinde dev provider başlatılamasın; sahte sağlayıcı üzerinden SMS istenen telefona yönlensin; yakalanan loglarda OTP veya tam telefon bulunmasın.

Kanıt: B/lib/sms/dev-sms-provider.ts:4 · B/features/auth/otp.service.ts:25 · B/features/gifts/gifts.service.ts:74

Backend: para, güvenlik ve iş kuralları / devam

BE-03 | P1 / YÜKSEK | STATİK KANIT

POS'a iletilmediği halde sipariş iletilmiş işaretleniyor

DevKerzzPosClient.forwardOrder sadece log+Order.update yapar. Global örnek koşulsuz dev; POS_DEV_AUTOADVANCE=false yalnız zamanlayıcıyı kapatır, sahte iletim onayını kapatmaz.

İşletmeye etkisi: Dev POS istemcisi ağ çağrısı yapmadan forwardedAt yazar. Kasaya ulaşmayan ücretli sipariş panelde iletilmiş görünür ve mini-outbox onu tekrar denemez.

Yapıyı koruyan çözüm: Üretimde gerçek Kerzz adaptörü zorunlu olsun; yalnız POS teslim alım teyidinden sonra forwardedAt yazılsın. Adaptör hazır değilse sipariş alımı kontrollü kapatılsın; geliştirme simülasyonu ayrı kalsın.

Kabul kontrolü: POS timeout/5xx durumunda forwardedAt null kalmalı, tekrar deneme ve operatör alarmı görünmeli; teslim teyidi alan aynı sipariş yeniden oluşturulmamalı.

Kanıt: B/features/orders/pos-client.ts:24 · B/features/orders/pos-client.ts:51

BE-04 | P1 / YÜKSEK | İZOLE DB TESTİ

Dondurulan müşteri hesabı finansal işlemlere devam ediyor

izole blockedOrder senaryosunda bloke hesap POST /orders -> 201; bakiye 1000 -> 810. requireAuth yalnız JWT doğrular. setBlocked refresh tokenları iptal etse de yeni girişte isBlocked kontrolü yok; yalnız gift-claim alıcı kontrolü yapıyor.

İşletmeye etkisi: Dondurma işlemi harcamayı durdurmuyor. Hesap kötüye kullanımı ve inceleme sırasında işlem engeli çalışmıyor.

Yapıyı koruyan çözüm: Girişin açık kalması ürün kararıysa koruyun; para/hediye/sipariş/QR mutasyonlarında merkezi aktif-hesap kontrolü ve DB işleminde yeniden doğrulama ekleyin. Blokajın anlamını oturum silmeyle karıştırmayın.

Kabul kontrolü: Açık oturumlu kullanıcı bloklandıktan sonra yeni sipariş/topup/hediye/QR oluşturma ve mevcut QR tahsilatı reddedilsin; profil okumak ve kontrollü giriş politikasının beklenen davranışı ayrıca test edilsin.

Kanıt: B/middleware/auth.ts:18 · B/features/admin/customers.service.ts:292 · B/features/auth/auth.service.ts:19 · B/features/pos/pos.service.ts:24

Backend: para, güvenlik ve iş kuralları / devam

BE-05 | P1 / YÜKSEK | İZOLE DB TESTİ

POS iptal bildirimi müşteri parasını ve ikramını iade etmiyor

webhookCancel: 190 TL sipariş ardından webhook 200, bakiye 810 (beklenen 1000); admin cancel INVALID_STATUS_TRANSITION. Webhook doğrudan sadece durum değiştiren advanceOrderStatus çağırıyor.

İşletmeye etkisi: Sipariş CANCELLED olur ama cüzdan/ikram/damga geri alınmaz. Sonradan panel iptali zaten iptal hatası verdiği için normal iade yolu da kapanır.

Yapiyı koruyan çözüm: Panel ve POS iptalini tek idempotent iptal/iade servisine yönlendirin; statü, defter, cüzdan ve sadakat aynı transaction içinde değişsin. Daha önce bu şekilde iptal edilen siparişleri raporlayıp ayrı kontrollü telafi planlayın.

Kabul kontrolü: Aynı imzalı cancelled olayının sıralı/paralel tekrarında tek iade; kullanılan ikram geri döner, kazanım geri alınır; panel+webhook yarışı da toplam tek iade üretir.

Kanıt: B/features/webhooks/kerzz.routes.ts:30 · B/features/orders/order-status.service.ts:65 · B/features/admin/orders.service.ts:192

BE-06 | P1 / YÜKSEK | İZOLE DB TESTİ

Aynı siparişe eşzamanlı panel iptali çift iade üretiyor

Gerçek PostgreSQL transactionları okuma bariyeriyle eşzamanlandı: iki cancelOrder da başarılı; başlangıç 1000, siparişsonrası 810, ikiiptalsonrası 1190;2 REFUND. Koşulsuz order.update stale ön kontrolden sonra gerçekleşiyor.

İşletmeye etkisi: Sipariş tutarı iki kez cüzdana eklenir ve iki REFUND oluşur.

Yapiyı koruyan çözüm: İptal sahiplenmesini geçerli önceki statü koşullu updateMany veya satır kilidi ile yapın; count=0 durumunda ikinci iade yazmayın. İade için order+işlem türü benzersizliği eklenmesi ikinci savunma olur.

Kabul kontrolü: İki/10 paralel panel iptali ve panel-webhook yarışı: cüzdan tam bir kez artmalı, tek REFUND, tek sadakat ters kaydı oluşmalı.

Kanıt: B/features/admin/orders.service.ts:186 · dosso-dossi-backend/prisma/schema.prisma:215

Backend: para, güvenlik ve iş kuralları / devam

BE-07 | P1 / YÜKSEK | İZOLE DB TESTİ

Bir ikram hakkı iki paralel siparişte harcanabiliyor

doubleFreeDrink: iki başarılı siparişin total=0; final freeDrinks=-1. İkram kontrolü wallet kilidinden önce, düşüm sonradan koşulsuz mutlak değerle yapılıyor.

İşletmeye etkisi: İki bedelsiz içecek çıkar; freeDrinks=-1 olur. DB'de negatif hak kısıtı yok.

Yapıyı koruyan çözüm: Aynı transaction içinde ikramı freeDrinks>=1 koşuluyla atomik rezerve edin veya cüzdan/sadakat için tutarlı kilit sırası belirleyin; fiyatlama ve hak tüketimi aynı sahiplenmeye bağlı olsun.

Kabul kontrolü: Tek ikramla 10 paralel sipariştten en fazla biri ücretsiz kabul edilmeli; hak hiçbir durumda negatif olmamalı. Damga kazanımı ve başarısız işlem rollback'i de korunmalı.

Kanıt: B/features/orders/orders.service.ts:75 · B/features/orders/orders.service.ts:94 · B/features/loyalty/loyalty-apply.ts:22

BE-08 | P1 / YÜKSEK | İZOLE DB TESTİ

İlk yüklemeye özel bonus paralel yüklemelerde tekrar veriliyor

doubleBonus: iki farklı intent onayı sonrası freeDrinks 10, beklenen 5. previousTopUps sayımı cüzdan satır kilidinden önce.

İşletmeye etkisi: Tek seferlik 5 kahve yerine 10 kahve verilir; intent başına idempotency kullanıcı başına tek kampanya hakkını korumuyor.

Yapıyı koruyan çözüm: Kampanya hakkını kullanıcı+kampanya benzersiz kaydıyla atomik sahiplenin veya aynı cüzdanı sayımdan önce kilitleyin. Kampanya okuması ve kararın tutarlı snapshot içinde olmasını sağlayın.

Kabul kontrolü: İki farklı ilk intent paralel onaylandığında 2000 TL bakiye fakat yalnız 5 bonus; aynı intent tekrarları tek TOPUP. İlk yükleme eşik altındaysa mevcut iş kuralı korunmalı.

Kanıt: B/features/wallet/payments/topup.service.ts:100 · B/features/wallet/payments/topup.service.ts:128

Backend: para, güvenlik ve iş kuralları / devam

BE-09 | P1 / YÜKSEK | İZOLE DB TESTİ

Eşzamanlı sadakat olayları damga/hak güncellemesini kaybediyor

lostStamp: iki gerçek applyLoyalty transactionı ve 2 olay; final stamps 1, beklenen 2. Servis hesaplayıp mutlak stamps/freeDrinks yazar.

İşletmeye etkisi: Olay geçmişinde iki kazanım varken toplam damga bir kez artar. Mutlak freeDrinks yazımı başka işlemde atomik eklenen hakkı da ezebilir.

Yapiyı koruyan çözüm: Sadakat hesabına işlem başında satır kilidi veya compare-and-swap/sürümleme+retry ekleyin; tüm yazan servisler ortak kilit sırasına uysun.

Kabul kontrolü: Farklı saleId ile 10 paralel satışın toplam damga ve ikramı matematiksel toplamla eşleşmeli; hediye/bonus ile eşzamanlılıkta hak kaybolmamalı.

Kanıt: B/features/loyalty/loyalty-apply.ts:22 · B/features/webhooks/kerzz-sale.service.ts:32

BE-10 | P1 / YÜKSEK | İZOLE DB TESTİ

Paralel manuel eksi bakiye düzeltmesi cüzdanı negatife düşürüyor

negativeBalance izole testi final-60 TL. before+amount kontrolü ayrı okuma, güncelleme koşulsuz increment.

İşletmeye etkisi: Ön kontrolü ikisi de geçer; cüzdan-60 TL olur. Muhasebe ve yetersiz bakiye kuralı bozulur.

Yapiyı koruyan çözüm: Negatif düzeltmede balance>=abs(amount) koşullu atomik decrement kullanın; count=0 yetersiz bakiye. Defter/audit aynı transaction içinde kalsın.

Kabul kontrolü: 100 TL için iki paralel-80 düzeltmenin yalnız biri başarılı olsun; final 20 TL, tek düzeltme defteri/audit; diğer işlem temiz hata dönsün.

Kanıt: B/features/admin/customers.service.ts:195

Backend: para, güvenlik ve iş kuralları / devam

BE-11 | P1 / YÜKSEK | İZOLE DB TESTİ

Kuruş altı tutarlar cüzdan, hediye ve defter arasında para tutarsızlığı oluşturuyor

rounding: başlangıç 1 TL, bakiye 1 TL (delta 0), ledgerAmount-0.01 TL, giftAmount 0.01 TL. Zod yalnız positive/max uygular; dec() yuvarlamaz, DB Decimal(10,2) ayrı ayrı yuvarlar.

İşletmeye etkisi: Farklı SQL alanlarında yuvarlama farklı yönde sonuçlanır; gönderende para düşmeden alıcıya kredilendirilecek 0.01 TL hediye doğar. Mutabakat değişmezi bozulur.

Yapıyı koruyan çözüm: Sınırdaki tek para politikası belirleyin: tam kuruş cinsinden integer veya Decimal ile en fazla 2 hane doğrulama. Bir kez normalize edilmiş tutarı tüm bakiye/defter/sağlayıcı alanlarında kullanın; promosyon hesabında da aynı yuvarlama kuralı olsun.

Kabul kontrolü: 0.001/0.005/1.005 girdileri 400 dönmeli ya da açık politika gereği tek değere normalize edilmeli; her hareket için $\text{balanceAfter} - \text{balanceBefore} = \text{ledgerAmount}$, toplam transfer korunumu sağlanmalı.

Kanıt: B/features/gifts/gifts.schemas.ts:8 · B/features/gifts/gifts.service.ts:33 · B/lib/money.ts:8 · B/features/wallet/wallet.schemas.ts:4 · B/features/pos/pos.schemas.ts:7

BE-12 / MOB-04 | P1 / YÜKSEK | İZOLE DB TESTİ

Müşteri sipariş/yükleme/hediye başlangıcında tekrar isteğine karşı idempotency yok

duplicatePost: aynı POST /orders gövdesi iki kez 201; 2 sipariş, 1000 → 620. Şemada istemci işlem anahtarı yok. Topup her çağrıda yeni intent; gift her çağrıda yeni gift.

İşletmeye etkisi: Tek kullanıcı niyeti iki sipariş, iki hediye veya iki ödeme başlangıcına dönüşebilir. Dakikalık limiter tekrar güvenliği değildir.

Yapıyı koruyan çözüm: Kullanıcı+işlem türü+idempotencyKey benzersiz kaydını transactiona ekleyin; aynı anahtar/aynı içerik önceki sonucu dönsün, farklı içerik 409 olsun. Eski mobil sürümler için aşamalı sözleşme geçişi yapın. Mobil aynı niyet için işlem kimliğini kalıcı tutmalı; yükleme sürerken ikinci onay engellenmeli. Belirsiz sonuçta tekrar oluşturmak yerine işlem durumu sorgulanmalı.

Kabul kontrolü: Aynı anahtarla 10 paralel istek tek finansal olay; yanıt kaybı sonrası tekrar aynı kimliği döndürmeli. Farklı anahtarlarla bilinçli iki sipariş kabul edilmeli. Uygulama yeniden açılınca belirsiz işlem aynı kimlikle çözülmeli.

Kanıt: B/features/orders/orders.schemas.ts:3 · B/features/orders/orders.routes.ts:11 · B/features/wallet/payments/topup.service.ts:26 · B/features/gifts/gifts.service.ts:42 · M/features/scan_pay/presentation/scan_pay_screen.dart:508

Backend: para, güvenlik ve iş kuralları / devam

BE-13 | P2 / ORTA | İZOLE DB TESTİ

İçecek hediyesine sunucu tarafında ürün uygunluk sınırı uygulanmıyor

giftEligibility: izole 1 TL aktif mug-konik ürünü kendine hediye edildi; bakiye 100 -> 99, freeDrinks 0 -> 1. Ürünün stampMultiplier=0 olması reddedilmedi.

İşletmeye etkisi: Gönderici o ürünün fiyatını öderken alıcıya herhangi uygun kahvede tüketilebilen genel ikram hakkı eklenir. Ucuz ürün varsa fiyat farkı istismarına ve yanlış ürün davranışına yol açar.

Yapıyı koruyan çözüm: Hediye edilebilir içecekleri sunucuda açık eligibility alanı/kuralı ile sınırlandırın. Ürün bazlı hediye mi genel ikram mı olduğuna karar verip fiyat/hak sözleşmesini eşitleyin; kendine hediye yasağı ancak ürün kararıysa ekleyin.

Kabul kontrolü: Merch/paket çekirdek/uygun olmayan ürüne drink isteği 400 dönsün; seçilen hediye ürününün kullanım ve fiyat kuralı uçtan uca tutarlı olsun.

Kanıt: B/features/gifts/gifts.service.ts:18 · B/features/gifts/gift-claim.ts:50

BE-14 | P1 / YÜKSEK | İZOLE HATA SENARYOSU

SMS hatası para düşülmüş hediye istemciye başarısız gösteriyor

giftSmsCommit: test içi sağlayıcı hata enjeksiyonu sonrası sendGift hata verdi; bakiye 100 -> 80 ve 1 gift kalıcı. SMS transaction sonrası await ediliyor.

İşletmeye etkisi: Kullanıcı başarısız yanıt alır ama para düşmüştür ve hediye oluşmuştur; tekrar göndermek BE-12 nedeniyle ikinci hediye/borç doğurabilir.

Yapıyı koruyan çözüm: Hediye ile aynı transactionda bildirim outbox kaydı oluşturun; hediye sonucunu başarılı dönüp SMS teslimini ayrı retry durumuyla yönetin. İdempotency ekleyin.

Kabul kontrolü: SMS timeout olduğunda tek gift ve tek debit oluşsun; API hediye kimliği ve bildirim bekliyor durumunu döndürsün; background retry yalnız bildirimi tekrarlasın.

Kanıt: B/features/gifts/gifts.service.ts:72

Backend: para, güvenlik ve iş kuralları / devam

BE-15 | P2 / ORTA | İZOLE DB TESTİ

OTP tüketimi atomik değil

otpReplay: rastgele test OTP'si 234567 (dev master değil) iki eşzamanlı consumeOtp çağrısında da kabul edildi. consumedAt güncellemesinde önceki durum/attempts koşulu yok.

İşletmeye etkisi: Tek kullanımlık olması gereken kod iki başarılı oturum kurma akışına girebilir. Yanlış deneme sayacı ve gönderim limiti de ayrı okuma/yazma olduğu için paralel sınır aşmaları statik risk taşır.

Yapıyı koruyan çözüm: Doğru OTP tüketimini id+consumedAt:null+expiresAt>now+attempts<limit koşullu update ile sahiplenin; yalnız count=1 başarılı olsun. Deneme/gönderim sınırlarını da atomik uygulayın.

Kabul kontrolü: Aynı geçerli OTP'ye 10 paralel doğrulama yalnız 1 başarı; yanlış denemelerde toplam izinli deneme sayısı aşılmaz; daha yeni kod üretildiyse eskisinin geçersizliği açıkça test edilsin.

Kanıt: B/features/auth/otp.service.ts:39 · B/features/auth/otp.service.ts:18

BE-16 | P2 / ORTA | İZOLE DB TESTİ

Kapalı/bilinmeyen ürün opsiyonu siparişte ücretsiz kabul ediliyor

disabledOption: pasif Yulaf sütü ve başka aktif opsiyon varken 190 TL latteye Yulaf sütü yazıldı; subtotal 190 kaldı. optionDelta bilinmeyene 0 döner, şema serbest string.

İşletmeye etkisi: Siparişe mevcut olmayan opsiyon yazılır, fiyat farkı 0 kabul edilir. Şube hazırlık ve fiyat sözleşmesi ayrışır.

Yapıyı koruyan çözüm: Boş/standart seçimi açıkça destekleyip diğer opsiyonları aktif katalog, grup ve ürüne uygunluk açısından doğrulayın. Tüm opsiyonlar bilerek kapalıysa fallback ile geri açmayın.

Kabul kontrolü: Pasif/bilinmeyen/grubu yanlış opsiyon 400; standart opsiyon normal fiyat; aktif yulaf sütü tam tanımlı fiyatla kabul edilmeli.

Kanıt: B/features/orders/orders.service.ts:15 · B/features/orders/orders.service.ts:50 · B/features/orders/orders.schemas.ts:11 · B/features/menu/options.service.ts:21

Backend: para, güvenlik ve iş kuralları / devam

BE-17 | P2 | ORTA | İZOLE DB TESTİ

Sipariş detayı iade hareketini göstermiyor

missingRefundLink: DB'de 1 REFUND varken getOrderDetail.walletTransactions yalnız ORDER_PAYMENT. İade orderId yazmaz; çünkü schema orderId @unique ve ödeme kaydı zaten tutar.

İşletmeye etkisi: Para gerçekten iade edilmiş olsa da siparişe ait hareket sorgusunda sadece ödeme görünür; müşteri destek ve muhasebe izlenebilirliği eksilir.

Yapıyı koruyan çözüm: Sipariş birden çok defter hareketine bağlanabilsin; tek ödeme/tek iade için işlem türüne özgü benzersizlik veya referans tablosu kullanın. Geriye dönük bağları kontrollü migration ile tamamlayın.

Kabul kontrolü: İptal edilmiş sipariş detayında ORDER_PAYMENT ve REFUND, doğru tutar ve aynı order referansı görünmeli; çift iade benzersizliği ayrıca korunmalı.

Kanıt: B/features/admin/orders.service.ts:95 · B/features/admin/orders.service.ts:212 · dosso-dossi-backend/prisma/schema.prisma:222

BE-20 | P2 | ORTA | STATİK RİSK

Rate limiter temizliği yeni anahtar akışında atlanıyor; OTP gönderimi IP kotasına sahip değil

Yeni/expired bucket dalı line 30-33 return eder; temizlik yalnız mevcut aktif anahtarın limit altı yolunda 43-47. OTP send route limiter yok; service yalnız telefon başına count/insert yapar. Çoklu instance eksikliği yorumda da belirtilmiş.

İşletmeye etkisi: Map anahtarları yeni isteklerde temizlenmeden büyüyebilir. Telefon başına kota, çoklu telefon isteklerinde global kaynak/SMS maliyetini sınırlamaz. Birden fazla sunucuda limitler ortak değildir.

Yapıyı koruyan çözüm: Temizliği tüm dallardan bağımsız zamanlayıcı/TTL store ile yapın ve kapasite sınırı koyun. Normalize telefon+IP+global gönderim kotası, sağlayıcı bütçe alarmı; çoklu instance için atomik ortak store.

Kabul kontrolü: Sanal saatle20bin farklı anahtar sonra TTL ilerletildiğinde map sınırlı kalmalı; tek IP farklı telefonlarla belirlenen limiti aşmamalı; parallel send kotası atomik olmalı.

Kanıt: B/middleware/rate-limit.ts:19 · B/features/auth/auth.routes.ts:26 · B/features/auth/otp.service.ts:18

Backend: para, güvenlik ve iş kuralları / devam

BE-21 | P2 | ORTA | STATİK RİSK

Üretim secret doğrulaması zayıf müşteri JWT anahtarını kabul edebilir

JWT_SECRET min 8, admin/HMAC min 16; production guard yalnız bazı örnek alt metinleri ve müşteri/admin eşitliğini reddeder. Entropi/rastgele üretim iş akışı kaynaktan garanti değil.

İşletmeye etkisi: Tahmin edilebilir JWT secret kullanılırsa sahte oturum oluşturma riski doğar. Mevcut gerçek secretın zayıf olduğu tespit edilmedi.

Yapiyı koruyan çözüm: Üretimde en az 32 byte rastgele oluşturulmuş bağımsız anahtarları secret manager üzerinden sağlayın; örnek/varsayılanları reddedin. Kısa anahtar kuralını yükseltirken güvenli planlı rotation ve oturum etkisini yönetin.

Kabul kontrolü: 8/16 karakter basit üretim değerleri başlangıçta reddedilmeli; geçerli32byte secretlarla üretim başlatılmalı; secret hiçbir log/rapora yazılmamalı.

Kanıt: B/config/env.ts:12 · B/config/env.ts:63

BE-23 | P2 | ORTA | STATİK RİSK

Başarısız POS denemesinin geç hata kaydı başarılı tekrarın durumunu geri bozabilir

runPosEvent hata yakalarken transaction dışı posEvent.update({id,status:FAILED}) koşulsuzdur. İşleme sahiplenmesi FAILED/RECEIVED kabul eder; sürüm/attemptId yok.

İşletmeye etkisi: Başarılı olay FAILED görünür ve sonraki retry tekrar handler çalıştırabilir. Charge/payment entity guardları ayrı savunma sağlar; sale gibi yalnız PosEvent idempotencyye dayanan yan etkiler tekrar edebilir.

Yapiyı koruyan çözüm: Hata durumunu aynı attempt/version şartıyla veya yalnız halen RECEIVED olan olaya conditional update ile yazın; başarı durumunu eski deneme asla geriye alamamalı. Payload fingerprint kontrolü de anahtar yeniden kullanımında yararlıdır.

Kabul kontrolü: Bariyerli A-fail/B-success/A-late-error sırası sonunda tek yan etki, PROCESSED durum; C retry cached response dönmeli. Farklı payloadla aynı event key 409 olmalı.

Kanıt: B/features/webhooks/pos-events.service.ts:83 · B/features/webhooks/pos-events.service.ts:113 · B/features/webhooks/pos-events.service.ts:60

Backend: para, güvenlik ve iş kuralları / devam

BE-24 | P1 / YÜKSEK | KOD / YAPILANDIRMA

npm start betiği derlenen giriş dosyasının yanlış yoluna işaret ediyor

Kaynak değiştirilmeden `tsc --outDir /tmp/dosso-prod-audit-20261002/backend/build --listEmittedFiles` exit 0. Eşdeğer çıktı kökünde `index.js` yok, `src/index.js` mevcut. `package.json` `start=node dist/index.js`; `rootDir=`. olduğundan `src` klasörü çıktı içinde korunuyor.

İşletmeye etkisi: TypeScript derlemesi başarılı olsa da beklenen `dist/index.js` oluşmaz; standart başlangıç komutu uygulamayı başlatamaz.

Yapıyı koruyan çözüm: Derleme düzenini koruyarak `start` betiğini `node dist/src/index.js` yapın veya `build` için yalnız `src` köklü ayrı `tsconfig` tanımlayın. Geliştirme `tsx watch` akışını değiştirmeye gerek yok.

Kabul kontrolü: Temiz geçici `build` çıktısında `package` `start` hedefi var olmalı; izole üretim konfigürasyonu/DB ile başlangıç ve `health smoke` geçmeli.

Kanıt: `dosso-dossi-backend/package.json:8` · `dosso-dossi-backend/tsconfig.json:7`

Admin: erişim ve operasyon doğruluğu

Her bulgu: gözlenen davranış, etkisi, en küçük güvenli düzeltme ve kapanış testi. B/ backend, M/ mobil, A/ admin kaynaklarını belirtir. Kod bağlantıları incelenen commit'e gider.

ADM-01 | P1 / YÜKSEK | İZOLE BELLEK PROBU

Hesap değiştirildiğinde önceki yöneticinin verileri panelde kalıyor

Süper yönetici paneli kullandıktan sonra aynı sekmede çıkış yapıp 30 saniye içinde bir şube müdürü hesabıyla giriş yapar. cross-session-cache-reuse: nextAccountFetchCalls=0, önceki global veri geri döndü.

İşletmeye etkisi: Query anahtarları kullanıcı/rol/şube içermediği ve çıkışta QueryClient temizlenmediği için önceki hesabın global ciro, sipariş, müşteri ve yönetici verileri yeni hesaba gösterilebilir. Süre dolsa bile eski veri yeni istek sonuçlanana kadar cache içinde kalır; devam eden eski istekler de cache'i yeniden doldurabilir.

Yapıyı koruyan çözüm: Oturum değişiminde önce bekleyen sorguları iptal et, QueryClient.clear() uygula; auth scope veya sessionId'yi queryKey'lere ekle. Auth değişiminden önce sonuçlanan eski isteklerin yeni cache'e yazılmasını da engelle.

Kabul kontrolü: Aynı tarayıcı sekmesinde A hesabının müşteri/finans ekranını aç, çıkış yap ve B şube hesabıyla gir. B ilk frame'den itibaren A verisini hiç görmemeli; ağ geciktirilerek aynı kontrol tekrarlanmalı.

Kanıt: A/App.tsx:17 · A/auth/AuthContext.tsx:54 · A/features/dashboard/DashboardPage.tsx:29

ADM-02 | P1 / YÜKSEK | İZOLE BELLEK PROBU

Şube müdürünün CRM, finans ve POS okumaları şubeyle sınırlanmıyor

BRANCH_MANAGER token'ıyla /admin/customers, /admin/customers/:id, /admin/finance/ledger(.csv/.xlsx), /admin/finance/payments, /admin/finance/charges veya /admin/pos/events çağrılır. branch-manager-customer-route: BRANCH_MANAGER branch-1 rolüyle gerçek /customers handler'ı authorized=true, Prisma where={} sonucunu verdi.

İşletmeye etkisi: Sipariş ve şube ekranlarında uygulanan şube kısıtı bu uçlarda bulunmuyor. Herhangi bir şube müdürü tüm müşterilerin telefon/e-posta/bakiye/hediye bilgileri ile global mali deftere ve POS payload/response içeriklerine erişebilir. Şubesi atanmamış müdür de bu global uçlarda scopeBranch kontrolünden geçmez.

Yapıyı koruyan çözüm: Global cüzdan/CRM/POS erişimine açık bir rol matrisi tanımla. Şube ile ilişkilendirilemeyen global verileri BRANCH_MANAGER için 403 yap; şubeye ait sipariş/müşteri görünümünü sunucuda ayrı dar kapsamlı DTO ile sağla. Menü gizleme tek başına yeterli değildir.

Kabul kontrolü: B 1 müdürü, B 2 müşterisi/siparişi/finans veya ham POS olayını okuyamamalı; direct HTTP ve CSV/XLSX uçları da aynı kapsam testlerine tabi olmalı.

Kanıt: B/middleware/admin-auth.ts:84 · B/features/admin/modules.routes.ts:345 · B/features/admin/modules.routes.ts:411 · B/features/admin/modules.routes.ts:495 · B/features/admin/customers.service.ts:15

Admin: erişim ve operasyon doğruluğu / devam

ADM-03 | P1 / YÜKSEK | İZOLE BELLEK PROBU

Admin şifre sıfırlama ve çıkış işlemi mevcut access token'ı iptal etmiyor

Geçerli bir access token tutulur; yönetici çıkış yapar veya şifresi sıfırlanır. Eski token ile yeni istek yapılır. admin-access-after-revoke: refresh iptali2kez çalıştı, eski accessAccepted=true.

İşletmeye etkisi: Yalnız refresh token kayıtları iptal ediliyor. Hesap aktif kaldığı sürece access JWT varsayılan 15 dakikalık ömrünü tamamlayana kadar kabul edilir. Şüpheli oturumu kapatma/şifre sıfırlama anlık erişim kesme işlevini sağlamaz. Pasifleştirme ve rol düşürme ise her istekte DB'den kontrol edildiği için ayrı olarak doğru çalışıyor.

Yapıyı koruyan çözüm: AdminUser üzerinde sessionVersion veya tokensValidAfter tut; access JWT'ye sürüm/iat koy ve requireAdmin'de doğru. Parola sıfırlama ve tüm oturumları kapatma işlemlerinde sürümü atomik artır; tek oturum çıkışı için sessionId temelli iptal de değerlendir.

Kabul kontrolü: Çıkış/şifre sıfırlamasından önce alınmış token, işlem tamamlanır tamamlanmaz korunmuş bir uçta 401 vermeli; yeni giriş token'ı çalışmalı.

Kanıt: B/features/admin/admin-auth.service.ts:135 · B/features/admin/admins.service.ts:132 · B/middleware/admin-auth.ts:27 · B/middleware/admin-auth.ts:64

ADM-04 | P1 / YÜKSEK | STATİK KANIT

Canlı sipariş panosu eski aktif siparişleri gizleyebiliyor

Bir aktif siparişin ardından en az 25 daha yeni kayıt gelir. Alternatif olarak Tüm Siparişler'de bir durum/arama filtresi seçilip Canlı Pano'ya geçilir.

İşletmeye etkisi: Pano bütün durumlar arasındaki yalnız ilk 25 yeni kaydı alıp tarayıcıda aktif sütunlara ayırıyor; eski bekleyen siparişler görünmez oluyor ve panoda sayfalama yok. Gizli kalan liste filtreleri panoya da uygulanabiliyor; örneğin COMPLETED filtresinden sonra aktif pano Boş görünür.

Yapıyı koruyan çözüm: Pano için sunucuda aktif durumlar kümesini getiren ayrı filtre/query oluştur; aktif siparişler tüm sayfaları veya imleçli devamı kapsasın. Liste filtrelerini pano sorgusundan ayır ve toplam bekleyen sayısını sunucudan al.

Kabul kontrolü: 30 tamamlanmış yeni sipariş ve onlardan eski bir RECEIVED sipariş içeren fixture'da eski aktif sipariş görünmeli. Listeye COMPLETED filtresi verilir panoya geçildiğinde aktif üç sütun etkilenmemeli.

Kanıt: A/features/orders/OrdersPage.tsx:114 · A/features/orders/OrdersPage.tsx:211 · A/features/orders/OrdersPage.tsx:249 · A/features/orders/OrdersPage.tsx:300 · B/features/admin/orders.service.ts:40

Admin: erişim ve operasyon doğruluğu / devam

ADM-05 | P1 / YÜKSEK | İZOLE BELLEK PROBU

Para ve sadakat ayarları yanlış tip veya aralıkla kaydedilebiliyor

Süper yönetici ikram sayısına 1.5 veya negatif eşik yazar; API'den firstOnly için boolean yerine "false" string'i gönderilir. actual-settings-validator: üç geçersiz örnek de accepted=true.

İşletmeye etkisi: Şema yalnız number|boolean|string kabul ediyor; anahtara özgü doğrulama yok. 1.5 ikram değeri ödeme onayında integer DB alanına gider ve onayı başarısız yapabilir. Negatif eşik her pozitif yüklemeyi uygun sayar; "false" string'i JavaScript'te truthy olduğu için beklenen kurala uymaz. Yanlış ayar finansal akışa doğrudan taşınıyor.

Yapıyı koruyan çözüm: Anahtara göre discriminated union kullan: stampTarget pozitif sınırlı integer, bonusDrinks sıfır veya pozitif sınırlı integer, eşik pozitif iki haneli para, firstOnly gerçekboolean. Aynı sınırları formda göster ve kaydı açık onay düğmesine bağla.

Kabul kontrolü: 1.5 ikram, negatif eşik, metin boolean ve geçersiz stampTarget istekleri 400 dönmeli; ayar ve audit değişmemeli. Geçerli değerler mevcut topup testlerini bozmamalı.

Kanıt: B/features/admin/modules.routes.ts:284 · B/features/settings/settings.service.ts:46 · B/features/wallet/payments/topup.service.ts:108 · A/features/campaigns/CampaignsPage.tsx:424

ADM-06 | P2 / ORTA | STATİK KANIT

Paneldeki damga hedefi ayarı uygulama kuralını değiştirmiyor

Sadakat kurallarında loyalty.stampTarget 5'ten 10'a değiştirilir.

İşletmeye etkisi: Ayar Setting tablosuna ve audit'e kaydediliyor fakat getSetting(stampTarget) çağrısı hiçbir işservisinde yok. Mevcut ve yeni LoyaltyAccount.target, şemadaki 5 varsayımı veya kayıtlı değerle devam ediyor. Panel metni değişikliğin uygulamanın davranışını belirlediğini söylüyor.

Yapıyı koruyan çözüm: Mevcut hesapların birikmiş damgalarına nasıl uygulanacağına karar ver; hedefi tek otoriteden oku veya sürümlü hedef değişimi/migrasyonu yap. Bu hazır değilse işlevsiz ayarı düzenlenemez yaparak yanlış beklentiyi önle.

Kabul kontrolü: Hedef 10 seçildikten sonra hem yeni hem mevcut hesap için kararlaştırılan kuralla 10. damgada ikram oluşmalı; eski birikim kaybolmamalı.

Kanıt: B/features/settings/settings.service.ts:10 · B/features/auth/auth.service.ts:30 · dosso-dossi-backend/prisma/schema.prisma:331 · B/features/loyalty/loyalty-apply.ts:33 · A/features/campaigns/CampaignsPage.tsx:399

Admin: erişim ve operasyon doğruluğu / devam

ADM-07 | P2 / ORTA | İZOLE BELLEK PROBU

CSV dışı aktarımları kullanıcı metnini formül olarak açtırabiliyor

Müşteri ismini =1+1 gibi formül başlangıcıyla kaydeder ve yönetici sipariş veya cüzdan CSV'sini Excel'de açar. order-csv-formula ve ledger-csv-truncation: containsUnescapedFormula=true.

İşletmeye etkisi: CSV kaçış fonksiyonu yalnız ayraç/tırnak/yeni satırı ele alıyor. =,+, -, @ veya kontrol karakteriyle başlayan dış kaynaklı metinler metin olarak sabitlenmiyor. Excel gibi tüketiciler formülü değerlendirebilir; etki kullanılan sürüm/güvenlik ayarına bağlıdır. XLSX üreticisi string hücre kullandığından bu bulgu ona genellenmiyor.

Yapıyı koruyan çözüm: Ortak CSV metin hücresi sterilizasyonu ekle; formül başlangıcı taşıyan metinleri güvenli bir metin önekiyle sabitle ve RFC uyumlu tırnakla. Sayısal tutarların veri tipini değiştirmeden yalnız dış kaynaklı metinlere uygula.

Kabul kontrolü: =1+1, +SUM(...), @SUM(...), tab/CR ile başlayan müşteri ve not fixture'ları CSV'den yeniden açıldığında düz metin olmalı; Türkçe karakter ve noktalı virgül korunmalı.

Kanıt: B/features/admin/orders.service.ts:346 · B/features/admin/finance.service.ts:201 · B/features/me/me.schemas.ts:4

ADM-08 | P2 / ORTA | İZOLE BELLEK PROBU

Cüzdan CSV raporu ilk 200 kayıtle sessizce kesiliyor

Muhasebe, seçili dönemde 200'den fazla hareket varken Cüzdan Defteri CSV indirir. ledger-csv-truncation: databaseCount 275, exportedRows 200, queryTake 200.

İşletmeye etkisi: CSV servisi sayfalı ledger fonksiyonunun yalnız birinci sayfasını 200 satırla çağırıyor; dosya adı/açıklaması kısmi olduğunu söylemiyor. Satır ve toplam eksik kalır. XLSX ayrıca 10.000, siparişCSV 5.000 sınırında sessiz kesilir; büyük hacim için bunlar da rapor sözleşmesinde açıklanmamış.

Yapıyı koruyan çözüm: Export için sayfaları keyset/cursor ile akış halinde dolaş veya dosya hazırlama işi kullan. Bilinçli sınır varsa kullanıcının göreceği açık satır/toplam/kapsam özeti ve tamamlanmadı uyarısı ekle.

Kabul kontrolü: 275 hareketten 275 satır çıkmalı ve CSV toplamı API toplamıyla eşleşmeli. Limitüstü kapsam ya tam üretilmeli ya da açık hata/uyarı vermeli.

Kanıt: B/features/admin/finance.service.ts:184 · B/features/admin/exports.service.ts:56 · B/features/admin/orders.service.ts:304 · A/features/finance/FinancePage.tsx:91

Admin: erişim ve operasyon doğruluğu / devam

ADM-09 | P2 / ORTA | İZOLE BELLEK PROBU

Sipariş Excel'i ekrandaki arama filtresini yok sayıyor

Siparişlerde bir müşteri adı veya DD numarası aranır, sonra Excel raporu indirilir. `xlsx-search-filter: q does-not-match` verilmesine rağmen `where={}` ve satır döndü.

İşletmeye etkisi: UI `q` parametresini gönderiyor ve route da servise geçiriyor; `ordersWorkbook` `where` içinde `q`'yu hiç kullanmıyor. Dosyaya seçilmemiş diğer müşteri/siparişler giriyor. CSV aynı filtreyi uyguladığı için iki dışa aktarım birbirini tutmuyor.

Yapıyı koruyan çözüm: Liste, CSV ve XLSX için aynı saf `OrderFilters` -> `where` dönüştürücüsünü kullan.

Kabul kontrolü: Aynı `q/status/branch/tarih` filtreleri altında listelenen IDs, CSV ve XLSX IDs kümeleri eşit olmalı.

Kanıt: `A/features/orders/OrdersPage.tsx:174` · `B/features/admin/orders.routes.ts:47` · `B/features/admin/exports.service.ts:163`

ADM-10 | P2 / ORTA | STATİK KANIT

Şube ürün müsaitliği değişikliği özel fiyatı siliyor

`BranchProduct.priceOverride` bulunan bir ürün panelden kapatılır veya tekrar açılır.

İşletmeye etkisi: Müsaitlik butonu her çağrıda `priceOverride:null` gönderiyor; servis bunu gerçekten null yazar. Şubeye özel fiyat onay alınmadan kaybolur ve temel fiyat devreye girer. UI özel fiyatı göstermediği için müdür fark etmeyebilir.

Yapıyı koruyan çözüm: Müsaitlik değişimini PATCH sözleşmesine çevir; gönderilmeyen `priceOverride` alanını koru, null yalnız açık fiyat temizleme işlemi olsun. Mevcut API korunacaksa UI satırdaki mevcut `override`'ı taşımalı.

Kabul kontrolü: Baz fiyat 190, şube fiyat 210 olan ürünü kapat/aç; `override` 210 değişmeden kalmalı. Açık fiyat temizleme işlemi ise bilinçli olarak 190'a dönmeli.

Kanıt: `A/features/branches/BranchesPage.tsx:287` · `B/features/admin/menu.service.ts:298`

Admin: erişim ve operasyon doğruluğu / devam

ADM-11 | P2 | ORTA | STATİK KANIT

POS yeniden kuyruğa alma düğmesi olayı kendisi yeniden işlemiyor

FAILED bir POS/ödeme olayı için Yeniden kuyruğa al seçilir ve dış sistem yeniden webhook göndermiyor.

İşletmeye etkisi: requeue yalnız durumunu RECEIVED yapıp hata bilgisini siliyor. Sistemde PosEvent RECEIVED kayıtlarını tüketen bir worker yok; runPosEvent yalnız yeni webhook/komut geldiğinde handler'la çağrılıyor. Operatörün aksiyonu sorunu çözmeden hata görünürlüğünü azaltıyor.

Yapıyı koruyan çözüm: Kayıtlı payload ve eventType'a göre aynı idempotent işleyiciyi kullanan gerçek bir tekrar işi ekle veya düğmeyi açıkça dış sistem tekrarını beklemeye alma olarak adlandır; sonuç/hata bilgisi işlem tamamlanana kadar korunsun.

Kabul kontrolü: Dış webhook gelmeden düğmeye basıldığında olay gerçekten bir kez yeniden işlenmeli ve PROCESSED/FAILED sonucuna geçmeli; finansal etki iki kez oluşmamalı.

Kanıt: B/features/admin/pos-monitor.service.ts:101 · B/index.ts:12 · B/features/orders/pos-client.ts:61 · B/features/webhooks/pos-events.service.ts:32

ADM-12 | P2 | ORTA | STATİK KANIT

Panel ürün görselini değiştirince grid fotoğrafı eski kalabiliyor

Grid fotoğrafı zaten bulunan ürünün Görsel URL alanı panelden güncellenir.

İşletmeye etkisi: Admin liste DTO'su gridImageUrl döndürmüyor ve form yalnız imageUrl düzenliyor. Backend güncellemede belirtilmeyen gridImageUrl'yi koruyor. Mobil grid preferGrid=true ile eski grid URL'sini seçerken detay yeni imageUrl'yi gösterir. Panelde değişiklik anlık yayılsa bile iki görünüm farklı kalır.

Yapıyı koruyan çözüm: Admin DTO ve forma ayrı grid/detay görsel alanlarını ekle veya tek görsel güncellemesinde grid türevini açık bir kuralla yeniden üret/temizle. Cache sürüm parametrelerini de güncelle.

Kabul kontrolü: Grid görselli ürünün fotoğrafı panelden değiştirildiğinde sipariş grid'i, hediye seçimi ve ürün detayı beklenen yeni görseli birlikte göstermeli.

Kanıt: B/features/admin/menu.service.ts:116 · A/features/menu/MenuPage.tsx:363 · B/features/admin/menu.service.ts:164 · M/core/widgets/product_image.dart:47

Admin: erişim ve operasyon doğruluğu / devam

ADM-13 | P2 / ORTA | STATİK KANIT

CRM harcama sıralaması tüm müşteriler yerine mevcut sayfayı sıralıyor

Müşterilerde Harcamaya göre sıralama seçilir; yüksek harcayan müşteri yeni kayıt sırasına göre ikinci veya sonraki sayfadadır.

İşletmeye etkisi: Önce createdAt desc ile sayfa çekiliyor, yalnız bu sayfanın harcamaları hesaplanıp sıralanıyor. Global en yüksek harcayan müşteriler ilk sayfaya gelmez; CRM analizi yanlış sıralama sunar.

Yapıyı koruyan çözüm: LTV sıralamasını toplam harcama join/aggregate sorgusunda pagination'dan önce uygula veya sorgulanabilir müşteri LTV özet tablosu kullan.

Kabul kontrolü: En eski fakat en yüksek harcayan müşteri, 25'ten çok müşterili fixture'da LTV sıralamasının ilk satırında olmalı.

Kanıt: B/features/admin/customers.service.ts:25 · B/features/admin/customers.service.ts:43 · B/features/admin/customers.service.ts:65

ADM-14 | P2 / ORTA | STATİK KANIT

Finans tablolarında kuruşlar yuvarlanarak gizleniyor

Cüzdan bakiyesi veya hareket 425,50 TL gibi kuruş içerir; yönetici finans tablosunu inceler.

İşletmeye etkisi: Ortak fmtTL maximumFractionDigits:0 kullanıyor. Gerçek 425,50 TL değer 426 TL görünür; listelenen tutarlar defter/XLSX değerleriyle uyuşmaz ve operatör manuel düzeltmeyi yanlış tutar üzerinden değerlendirebilir.

Yapıyı koruyan çözüm: Finans/cüzdan/ödeme gösteriminde minimumFractionDigits:2 ve maximumFractionDigits:2 kullan. KPI için kompakt yuvarlama gerekiyorsa ayrı formatter ve açık yaklaşık etiketi tanımla.

Kabul kontrolü: 0,01 TL, 425,50 TL ve negatif tutar ekran, CSV ve XLSX'te kuruş hassasiyetini korumalı.

Kanıt: A/components/ui.tsx:132 · A/features/finance/FinancePage.tsx:148

Mobil: doğru işlem ve hata dayanıklılığı

Her bulgu: gözlenen davranış, etkisi, en küçük güvenli düzeltme ve kapanış testi. B/ backend, M/ mobil, A/ admin kaynaklarını belirtir. Kod bağlantıları incelenen commit'e gider.

MOB-01 | P1 / YÜKSEK | İZOLE FLUTTER PROBU

401 sonrası başarısız yeniden deneme ağ kuyruğunu kilitliyor

Eski access token ile gelen 401, başka bir istek tarafından yenilenmiş tokenla tekrarlandığında tekrar isteği 401/503 veya başka Dio hatası verirse. Çevrimdışı probda retry 200 tamamlandı; retry 401/503 aynı hata kuyruğunu bekleyerek askıda kaldı.

İşletmeye etkisi: İlk onError tamamlanmadan ikinci onError aynı kuyrukta bekliyor. Future sonuçlanmıyor; giriş yenileme, sepet ödeme veya veri yükleme ekranı beklemede kalabiliyor. Diğer hata yanıtları da kuyruğun arkasında kalır.

Yapiyı koruyan çözüm: Token yenilemeyi tek paylaşılan Future ile eşgüdümle; tekrar isteğini aynı aktif hata kuyruğuna sokmayan ayrı, kontrollü istemciden geçir veya kuyruğu tamamladıktan sonra yeniden dene. En fazla bir auth retry kuralını koru.

Kabul kontrolü: 401 -> refresh -> 200, 401 -> refresh -> 401 ve 401 -> refresh -> 503 tamamlanmalı; hiçbir Future asılı kalmamalı. Aynı anda 5 adet 401 tek token rotasyonu üretmeli; ağ timeout ve logout yarışları da kapsanmalı.

Kanıt: M/core/network/api_client.dart:33 · M/core/network/api_client.dart:88

MOB-02 | P1 / YÜKSEK | STATİK KANIT

Onay ekranındaki fiyat ile gerçek tahsilat ayrışabiliyor

Admin seçenek fiyatını veya şubeye özel fiyatı değiştirir; müşteri eski/global fiyatı gördüğü sırada siparişi onaylar.

İşletmeye etkisi: Müşterinin "Öde" düğmesinde gördüğünden farklı tutar tahsil edilir. Sunucu hesabının güvenli olması doğru; fakat kullanıcı tutar onayı eksiktir. Şubede kapalı ürünler de ancak checkout sırasında reddedilir.

Yapiyı koruyan çözüm: Seçili şube için fiyat/uygunluk/opsiyon verisini istemciye ver; checkout öncesi sunucu fiyat teklifi veya expectedTotal/quoteVersion doğrulaması ekle. Fark çıkarsa tahsil etmeden güncel tutarı yeniden onaylat.

Kabul kontrolü: Global fiyat 200, şube fiyatı 210 olduğunda düğme 210 göstermeli veya ödeme öncesi değişiklik onayı istemeli. Yulaf fiyatı 60 -> 80 değişince detay/sepet güncellenmeli; yeni fiyat onaysız düşülmemeli. Şube değiştirilince kapalı ürünler ve fiyatlar yeniden kontrol edilmeli.

Kanıt: M/features/order/domain/product_options.dart:15 · M/features/order/data/api_menu_repository.dart:49 · M/features/order/presentation/cart_screen.dart:78 · B/features/orders/orders.service.ts:28

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-03 | P1 / YÜKSEK | STATİK KANIT

Gerçek ödeme için pending/3DS/kart akışı tamamlanmamış

Gerçek ödeme sağlayıcısı onay bekleyen işlem döndürür veya kullanıcı ilk kartını eklemek ister.

İşletmeye etkisi: Mobil 3DS ekranını açmaz, işlem durumunu takip etmez; para henüz onaylanmadan başarı mesajı gösterir. Kayıtlı kart Visa etiketi yalnız cüzdan son dört hanesidir; kart ekleme gerçek bir iş akışı değildir.

Yapıyı koruyan çözüm: Modeli paymentId/status/redirectUrl ile genişlet; sağlayıcının desteklenen güvenli ödeme akışını aç; yalnız sunucudan succeeded görüldüğünde bakiye başarı mesajı ver. Pending işlemi uygulama yeniden açılınca sürdürebil. Kart ekranını gerçek tokenizasyonla bağla.

Kabul kontrolü: Başarılı, reddedilen, iptal edilen, pending ve 3DS'den uygulamaya dönüş senaryoları sandbox sağlayıcıda doğrulanmalı. Pending hiçbir zaman "yüklendi" olmamalı; uygulama kapanıp açılınca aynı işlem bulunmalı.

Kanıt: M/features/wallet/data/api_wallet_repository.dart:26 · M/features/scan_pay/presentation/scan_pay_screen.dart:493 · M/features/scan_pay/presentation/scan_pay_screen.dart:538 · M/features/profile/presentation/saved_cards_screen.dart:65 · B/features/wallet/payments/topup.service.ts:51

MOB-05 | P1 / YÜKSEK | STATİK KANIT

Süresi dolmuş QR ödeme kodu geçerliymiş gibi gösteriliyor

QR yenilerken ağ kesilir, uygulama arka planda uzun kalır veya yenileme isteği bir saniyeden fazla sürer.

İşletmeye etkisi: Kasada süresi geçmiş kod gösterilir ve kalan süre yanlış olur. İlk yükleme hatasında kullanıcı açıklamasız bekler. Süre 1'de kalırken her saniye yeni istek başlayabilir; yanıtlar sırasız dönebilir.

Yapıyı koruyan çözüm: Gerçek expiresAt ve duvar saatiyle hesapla; süresi biten kodu gizle/işlevsizleştir, açık hata ve tekrar dene sun. Tek yenileme isteği uygula; ekrana dönüşte taze kod iste ve görünmeyen/arka plan sekmede timer'ı durdur.

Kabul kontrolü: Ağ kesikken QR süresi dolduğunda gösterilmemeli ve sayaç yeniden 60 olmamalı. 90 sn arka plan sonrası eski QR kullanılmamalı. Gecikmeli yanıtla en fazla bir QR isteği açık kalmalı; eski yanıt yenisini ezmeli.

Kanıt: M/features/scan_pay/presentation/scan_pay_screen.dart:45 · M/features/scan_pay/presentation/scan_pay_screen.dart:75 · M/features/wallet/data/api_wallet_repository.dart:46 · M/features/scan_pay/presentation/scan_pay_screen.dart:335

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-06 | P1 / YÜKSEK | STATİK KANIT

Android yayın imzası ve üretim adresi için koruma eksik

Belirlenen komutla varsayılan ayarlardan release APK/IPA üretilir.

İşletmeye etkisi: Android paketi debug anahtarıyla imzalanır. API adresi ayrıca verilmezse gerçek cihaz kendi localhost'una bağlanır ve temel akışlar çalışmaz. Bu tespit canlı dağıtım dosyasının böyle olduğu iddiası değildir; repo release yolunda açık kapıdır.

Yapıyı koruyan çözüm: Release için ayrı imzalama yapılandırmasını güvenli CI/secrets üzerinden zorunlu yap; release derlemede USE MOCKS=false ve izin verilen HTTPS API adresi yoksa build'i durdur. Mapbox public token/stil erişimi için build smoke kontrolü ekle.

Kabul kontrolü: İmzalı release artifact sertifikası debug olmamalı. Eksik/localhost/http API veya USE MOCKS=true ile production build bilinçli başarısız olmalı. Gerçek cihazdan HTTPS API, medya ve harita erişimi release modda denenmeli.

Kanıt: dosso-dossi-app/android/app/build.gradle.kts:33 · M/core/constants/app_config.dart:19 · dosso-dossi-app/dart_defines.example.json:1 · dosso-dossi-app/README.md:54

MOB-07 | P2 / ORTA | İZOLE FLUTTER PROBU

Hesaptan çıkınca sepet ve ikram seçimi sonraki hesaba kalıyor

Kullanıcı sepete ürün ekleyip ikramı seçer, çıkış yapar ve farklı hesapla giriş yapar. Gerçek provider'larla yapılan probda çıkış sonrası sepet 1 ürün ve useFreeDrink=true kaldı.

İşletmeye etkisi: Eski alışveriş niyeti yeni hesaba taşınır. Yeni hesapta hak yoksa ikram anahtarı görünmez, buna rağmen indirimli toplam/istek kalır ve sunucu siparişi reddeder. İn-flight checkout yanıtında oturum kimliği kontrol edilmemesi eski yanıtın yeni sepet/sipariş listesini etkilemesi riskini de doğurur.

Yapıyı koruyan çözüm: Çıkışta sepet, seçili şube ve ilgili bekleyen işlemleri açıkça sıfırla; misafir -> üye sepet taşıma isteniyorsa ayrı kural koy. Async sonuçları oturum nesli/kimliğiyle kontrol et; hak bittiğinde useFreeDrink=false yap.

Kabul kontrolü: A hesabının sepeti ve ikram seçimi B'ye taşınmamalı. Sipariş sürerken çıkış/giriş sonrası eski yanıt yeni hesabın listesini/sepetini değiştirmemeli.

Kanıt: M/features/auth/application/auth_controller.dart:92 · M/features/order/application/cart_controller.dart:16 · M/features/order/presentation/cart_screen.dart:604 · M/features/order/domain/cart.dart:87

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-08 | P2 / ORTA | İZOLE FLUTTER PROBU

Takip ekranı kapandıktan sonra periyodik timer oluşabiliyor

İlk sipariş takibi isteği yavaşken ekran/provider kapanır; yanıt daha sonra döner. FakeAsync probunda dispose sonrası geciken yanıt 1 periyodik timer oluşturdu.

İşletmeye etkisi: Dispose sırasında iptal edecek timer yoktur. Yanıt yeni 10 sn timer oluşturur; provider kapalı olmasına rağmen closure/timer kalır. Ekrana tekrarlanan hızlı gir-çık bellek/uyanma yükü biriktirebilir. Bu, uygulama kapandıktan sonra geçerli istek yapılabildiği iddiası değildir; dispose edilmiş ref okumaları catch tarafından yutulur.

Yapıyı koruyan çözüm: Her await sonrası ref.mounted kontrolü yap, yalnız görünür/ön plandaki ekranda poll et; bir istek tamamlanınca sonraki timer'ı planla, dispose'da istek iptal et.

Kabul kontrolü: İstek açıkken provider dispose edildiğinde yanıt sonrası sıfır aktif timer kalmalı. Yavaş aşda bir sipariş için aynı anda en fazla bir GET olmalı.

Kanıt: M/features/order/application/order_tracking_provider.dart:29 · M/features/order/application/order_tracking_provider.dart:38

MOB-09 | P2 / ORTA | STATİK KANIT

Liste görünümündeki Sipariş Ver seçilen kartın şubesini kullanmıyor

A şubesi aktifken liste ekranında B şubesinin Sipariş Ver düğmesine doğrudan basılır.

İşletmeye etkisi: Sipariş ekranı A şubesiyle açılır; müşteri B kartından geldiği için yanlış şubeye sipariş verebilir. Sepette şube adı görünmesi riski azaltır fakat yönlendirme niyeti yanlıştır.

Yapıyı koruyan çözüm: Liste kartının onOrder callback'inde ilgili branch'i seçtikten sonra sipariş rotasına geç; harita ve detayla aynı ortak aksiyonu kullan.

Kabul kontrolü: A aktifken B kartında Sipariş Ver -> activeBranch B olmalı. Harita, liste, detay ve sepet şube seçimi aynı sonucu vermeli.

Kanıt: M/features/branches/presentation/branch_list_screen.dart:47 · M/features/branches/presentation/branch_list_screen.dart:179 · M/features/branches/presentation/branch_detail_screen.dart:237

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-10 | P2 / ORTA | STATİK KANIT

Müşteri verisi yenileme ve hata durumları bazı ekranlarda sessiz kalıyor

Uygulama ön plandayken alıcıya hediye gelir veya müşteri geçmişini ilk açılışta ağ hatası alır; kullanıcı yenilemeye çalışır.

İşletmeye etkisi: Home pull-to-refresh para/ikramı güncellemez. Hesap verisi revision üretmeyen değişimlerde ekran eski kalabilir; hediye geçmişinde hata görünmez. Kullanıcı yükleme hatasını "kayıt yok" sanır. Admin revision kaynaklarıyla kapsanan değişimler için mevcut sync çalışıyor; "panel değişiklikleri hiç yansımıyor" iddiası doğru değil.

Yapıyı koruyan çözüm: Hesap ekranlarına açık loading/error/retry state ekle; pull-to-refresh ilgili cüzdan/sadakat/sipariş/hediye Future'larını beklesin. Hesap bazlı değişimleri revision veya olay akışına bağla, ekran açılış/resume için güvenli yeniden doğrulama yap.

Kabul kontrolü: Açık uygulamadaki alıcı hediye bakiye/ikramını belirlenen süre içinde görmeli. Ağ hatası boş geçmiş diye gösterilmemeli; Yeniden Dene kayıtları getirmeli. Home yenilemesi cüzdan ve sadakat GET'ini gerçekten tamamlamalı.

Kanıt: M/features/home/presentation/home_screen.dart:34 · M/core/sync/app_data_sync.dart:36 · M/features/gift/application/gift_controller.dart:24 · M/features/order/application/order_providers.dart:52 · M/features/profile/presentation/order_history_screen.dart:24 · B/features/sync/sync.service.ts:40

MOB-11 | P2 / ORTA | STATİK KANIT

Bildirim vaadi ile mobil entegrasyon ve tercih yazma davranışı ayrışıyor

Kullanıcı bildirim açar veya yavaş ağda tercihleri art arda değiştirir; daha eski GET/PUT yanıtı sonra döner.

İşletmeye etkisi: Mobil push teslimi uygulanmamıştır; tercih anahtarı bunun çalıştığı izlenimini verebilir. Yarışta eski istek hatası daha yeni başarılı seçimi cihazda geri alabilir; geç GET mevcut seçimi ezebilir.

Yapıyı koruyan çözüm: Push izin/token kaydı ve açılış yönlendirmesini sağlayıcıyla tamamla ya da özellik hazır olana kadar metni açıklaştı. Tercih yazmalarını sırala/sürümle; yalnız hâlâ son istek başarısızsa rollback yap ve kullanıcıya hatayı bildir.

Kabul kontrolü: Sipariş hazır bildirimini uygulama ön/arka planda ve kapalıyken kontrollü ortamda doğrulanmalı. GET/PUT yanıtları ters sırada geldiğinde son kullanıcı seçimi korunmalı; başarısız kaydetme görünür olmalı.

Kanıt: M/features/profile/application/notification_prefs.dart:10 · M/features/profile/presentation/notification_prefs_screen.dart:29 · M/features/profile/application/notification_prefs.dart:30 · M/features/profile/application/notification_prefs.dart:41 · dosso-dossi-app/pubspec.yaml:37

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-12 | P2 / ORTA | STATİK KANIT

Kampanya görsellerindeki kurallar panel ayarlarından beslenmiyor

Panelden yükleme eşiği/ödül sayısı değişir veya müşteri tekrar yükleme için SSS metnine güvenir.

İşletmeye etkisi: Sync başarılı olsa bile afiş eski 1000/5 kuralını gösterir; gerçek ödül farklı olabilir. SSS tüm uygun yüklemelerde hediye var izlenimi verirken afiş ve backend ilk yüklemeye özel diyor.

Yapıyı koruyan çözüm: Yapılandırılmış kampanya şartlarını API modeline ekleyip afiş/SSS/detay ve onay ekranını aynı kaynaktan üret. Sabitleri yalnız kontrollü mock fallback olarak tut.

Kabul kontrolü: Panel 1200 TL / 3 hediye yaptığında home/list/detail/SSS aynı değeri göstermeli. İlk yükleme koşulu tüm ilgili metinlerde açık ve tutarlı olmalı.

Kanıt: M/core/constants/app_config.dart:34 · M/features/campaigns/presentation/widgets/load_rewards_offer.dart:15 · M/features/campaigns/presentation/widgets/coffee_rewards_preview.dart:70 · M/features/profile/presentation/faq_screen.dart:26 · M/features/campaigns/presentation/widgets/campaign_discovery_card.dart:77

MOB-13 | P2 / ORTA | İZOLE WIDGET PROBU

Online Mağaza arama klavyesi dar görünümde gövdeyi taşıyor

375×667 mantıksal görünüm, üst güvenli alan 44 ve klavye 336 px olduğunda arama yapılır. İzole widget testinde 59 px alt kenar taşması ölçüldü. Gerçek Simulator veya platform klavyesi kullanılmadı.

İşletmeye etkisi: Grid'e alan kalmaz ve dış Column alt kenardan taşar; arama sonuçları/kontroller erişilemeyebilir. Mevcut 29 testin geçmesi tüm küçük ekran/metin ölçeği kombinasyonlarının geçtiği anlamına gelmez.

Yapıyı koruyan çözüm: Başlık/afiş/kategori ve grid'i ortak sliver scroll yapısında birleştir veya klavye açılınca afiş daralt/gizle; odaklı arama ve sonuç alanı kaydırılabilir. Gerçek fontlu küçük ekran testleri ekle.

Kabul kontrolü: 320×568 ve 375×667'de klavye açıkken 1.0/1.3/2.0 metin ölçeğinde tüm temel kontroller erişilebilir olmalı. Gerçek Poppins/Bricolage fontlarıyla overflow filtrelemeden doğrula.

Kanıt: M/features/shop/presentation/shop_screen.dart:69 · M/features/shop/presentation/shop_screen.dart:141 · M/features/shop/presentation/shop_screen.dart:200 · dosso-dossi-app/test/widget_test.dart:85

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-14 | P2 / ORTA | STATİK KANIT

İkon işlemlerinin bir bölümünde erişilebilir ad/rol yok

VoiceOver/TalkBack, büyük metin veya hassas dokunma gereksinimiyle alışveriş yapılır.

İşletmeye etkisi: Bazı ikonlar anlamsız odak noktaları olur; favori seçildi/seçilmedi ve kampanya üzerindeki güncel 3/5 ilerleme duyurulmaz. FittedBox, büyütülen yazıyı tekrar küçültebilir.

Yapıyı koruyan çözüm: İkonlara eylem adı, selected/toggled/button semantiği ekle; dokunma alanını yeterli büyüklükte tut; dinamik ilerlemeyi dış semantics label'a bağla. Büyük metni kritik tutar/düğmelerde küçültmek yerine sardır.

Kabul kontrolü: VoiceOver/TalkBack tüm sepet/favori/QR/ilerleme/sekme işlemlerini anlamlı adla okumalı. Flutter semantic accessibility guideline taraması ve gerçek cihaz dolaşımı yapılmalı.

Kanıt: M/features/shop/presentation/shop_screen.dart:259 · M/features/order/presentation/product_detail_screen.dart:205 · M/features/order/presentation/widgets/add_to_cart_button.dart:55 · M/features/home/presentation/widgets/campaign_carousel.dart:80

MOB-15 | P2 / ORTA | STATİK KANIT

Şube listesi boş olduğunda sipariş akışı açıklamasız kalıyor

Backend boş şube listesi döndürür, tüm şubeler pasifleşir veya ilk şube sorgusu başarısız olur.

İşletmeye etkisi: Provider StateError/AsyncError üretir. Sepette kullanıcı ödeme düğmesine basabilir ama görünür sonuç alamaz; geçerli şube yokluğu açıklanmaz.

Yapıyı koruyan çözüm: Boş listeyi beklenen domain durumu olarak modelle; "Şu anda sipariş verilebilen şube yok" ve tekrar dene göster. Şube geçerli/açık olmadan ödeme düğmesini etkinleştirme.

Kabul kontrolü: Boş şube, tümü kapalı, seçili şube silinmiş ve ağ hatası durumlarında çökme/sessiz ödeme olmamalı.

Kanıt: M/features/order/application/order_providers.dart:27 · M/features/branches/application/branch_providers.dart:11 · M/features/order/presentation/cart_screen.dart:56 · M/features/branches/presentation/branch_list_screen.dart:30

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-16 | P2 / ORTA | STATİK KANIT

Hazır/iptal edilmiş sipariş durumu geçmişten izlenemiyor

Sipariş hazır olduktan sonra iptal edilir veya müşteri iptal/tamamlandı bilgisini geçmişten kontrol eder.

İşletmeye etkisi: Hazır ekranı eski "Kasadan teslim al" durumunda kalabilir; geçmiş kartında iptal etiketi ve detay yolu yoktur. İade/bakiye ile sipariş durumu müşterinin gözünde tutarsız olabilir.

Yapiyı koruyan çözüm: Hazır aşamasını işin gerçek terminali kabul etme; tamamlandı/iptal olana kadar görünür ekranda takip sürsün veya revision olayına bağlansın. Geçmişte tüm durumları açık etiketle ve tüm kayıtlara okunur detay aç.

Kabul kontrolü: ready -> cancelled ve ready -> completed değişimi açık detayda görünmeli. İptal sipariş geçmişte iptal olarak işaretlenmeli ve detayına erişilmeli.

Kanıt: M/features/order/application/order_tracking_provider.dart:74 · M/features/order/domain/order_record.dart:28 · M/features/profile/presentation/order_history_screen.dart:49

MOB-17 | P2 / ORTA | STATİK KANIT

Gizlilik ekranı taslak; hesap silme talebi için uygulama akışı yok

Üretime çıkış ve kullanıcının hesabını/verisini sildirme talebi.

İşletmeye etkisi: Kullanıcıya onaylanmamış gizlilik metni gösterilir. Silme hakkı metinde anlatılır ama uygulamada doğrulanabilir talep yolu yoktur. Cihaz yedeği, profile cache ve saklama süreleri için belgelenmiş kontrol ayrıca doğrulanmalıdır.

Yapiyı koruyan çözüm: Onaylı ve sürümlü gizlilik metnini yayınla; kimliği yeniden doğrulanmış hesap silme/talep ve durum akışı tasarla. Finansal kayıtların gerekli saklanması ile kişisel profil silmesini ayır; cihaz cache temizliği ve yedek kapsamını test et.

Kabul kontrolü: Uygulamada taslak ibaresi kalmamalı; veri sorumlusu ve destek yolu doğrulanmalı. Hesap silme/talep işlemi oturumu ve yerel kişisel cache'i temizlemeli; sunucu durumu kullanıcıya bildirmeli.

Kanıt: M/features/profile/presentation/kvkk_screen.dart:7 · M/features/profile/presentation/profile_screen.dart:199 · M/core/network/api_endpoints.dart:7 · M/features/auth/application/auth_controller.dart:101

Mobil: doğru işlem ve hata dayanıklılığı / devam

MOB-18 | P3 / DÜŞÜK | STATİK KANIT

Gösterilen mesafe ve en yakın şube gerçek kullanıcı konumu değil

Kullanıcı sabit referans noktasından uzakta uygulamayı açar.

İşletmeye etkisi: Mesafe etiketi kullanıcının mesafesi sanılabilir; varsayılan sipariş şubesi gerçekten en yakın olmayabilir. Harita marker'larının koordinatı ayrı ve gerçek veriden gelir.

Yapiyı koruyan çözüm: Konum izni/GPS uygulamaya eklenene kadar mesafeyi gizle veya referansı açık belirt; ilk siparişte şubeyi kullanıcı seçsin. GPS eklenirse izin reddi için manuel şube akışını koru.

Kabul kontrolü: Konum izni yokken kişiye özel "en yakın" iddiası olmamalı; manuel seçim korunmalı.

Kanıt: M/features/branches/data/api_branch_repository.dart:10 · M/features/branches/application/branch_providers.dart:10 · M/features/order/application/order_providers.dart:33

MOB-19 | P2 / ORTA | STATİK KANIT

Token yenileme geçici ağ hatasını kalıcı oturum iptali sayıyor

Access token dolduğu sırada internet kesilir, refresh servisi 503 verir veya bağlantı hiç tamamlanmaz.

İşletmeye etkisi: Geçici hata kullanıcıyı zorunlu SMS girişine döndürür; takılan refresh ise auth hata kuyruğunu uzun süre tutabilir. Geçerli refresh token ağ hatası yüzünden yerelden silinir.

Yapiyı koruyan çözüm: Refresh için açık timeout/kısıtlı retry/backoff tanımla; yalnız refresh kimliği sunucudan açıkça geçersiz/revoked sonucu aldığı anda oturumu temizle. Ağ hatasında oturumu koruyup tekrar dene durumu göster.

Kabul kontrolü: Refresh timeout/503/offline oturumu silmemeli; invalid-refresh 401/403 kontrollü çıkış yapmalı. Refresh için üst süre sınırı olmalı ve tüm bekleyen istekler anlamlı hata ile tamamlanmalı.

Kanıt: M/core/network/api_client.dart:105 · M/core/network/api_client.dart:116 · M/core/network/api_client.dart:78

Operasyon ve bağımlılık güvenliği

Her bulgu: gözlenen davranış, etkisi, en küçük güvenli düzeltme ve kapanış testi. B/ backend, M/ mobil, A/ admin kaynaklarını belirtir. Kod bağlantıları incelenen commit'e gider.

OPS-01 | P2 / ORTA | BAĞIMLILIK TARAMASI

Backend bağımlılıklarında bilinen güvenlik duyuruları var

Üretim bağımlılık ağacında 7 etkilenen paket: 4 high, 3 moderate. Geliştirme dahil 12: 6 high, 6 moderate. Aynı kök duyuru üst paketleri de işaretlediğinden bunlar bağımsız 7 veya 12 uygulama açığı değildir. Admin ağacında audit 0 bulgu verdi. Uygulama üzerinden erişilebilir exploit yolu doğrulanmadı.

İşletmeye etkisi: Yayına çıkışta bilinen zayıf paketler taşınabilir; bu tarama uygulamada erişilebilir bir saldırı yolunu tek başına kanıtlamaz.

Yapiyı koruyan çözüm: Kilit dosyasını koruyarak ayrı bakım dalında desteklenen yamaları değerlendir; özellikle Prisma ve ExcelJS için audit önerdiği otomatik sürüm düşürmeyi uygulama. Kod yolu erişilebilirlik analizi + tüm regresyon + kontrollü bağımlılık güncellemesi.

Kabul kontrolü: Açık duyuruların her biri için yama veya belgeli erişilemezlik/risk kabulü; build, API, CSV/XLSX ve ödeme regresyonu temiz.

Kanıt: dosso-dossi-backend/package-lock.json · npm audit --omit=dev --json (02.10.2026) · npm ls prisma @prisma/config deepmerge-ts exceljs uuid brace-expansion qs --omit=dev

OPS-02 | P1 / YÜKSEK | DEPODA KANIT BULUNAMADI

Yayın, yedekten dönüş ve izleme kanıtları eksik

Depoda GitHub Actions/CI, production dağıtım tanımı, yedek/geri yükleme prosedürü ve alarm kuralları bulunmadı. README yalnız geliştirme akışını tarif ediyor; compose geliştirme DB tanımı. /health SELECT 1 ve yapılandırılmış log mevcut; bunlar dış izleme, veri kurtarma ve yük doğrulamasının yerini tutmaz. Harici altyapının yokluğu iddia edilmiyor, erişim verilmedi.

İşletmeye etkisi: Arıza, veri kaybı veya başarısız sürümde kimin ne kadar sürede toparlayacağı gösterilemiyor. Harici altyapı belgeleri sunulursa bu değerlendirme güncellenebilir.

Yapiyı koruyan çözüm: Mevcut modülleri koruyarak staging/release kontrol hattı, migrate deploy, TLS/secret yönetimi, DB+uploads yedeği, ayrı DB geri yükleme provası, alarm ve geri alma runbook ekle.

Kabul kontrolü: Tekrarlanabilir temiz kurulum ve deploy; şifreli yedekten geri dönüş kanıtı; onaylı RPO/RTO; hata, POS kuyruğu ve ödeme uyumsuzluğu alarmı.

Kanıt: README.md:12 · docker-compose.yml:1 · B/index.ts:9 · B/app.ts:24 · B/lib/logger.ts:13

Operasyon ve bağımlılık güvenliği / devam

OPS-03 | P2 / ORTA | STATİK ÖLÇEK RISKİ, YÜK TESTİ YAPILMADI

3 saniyelik senkronizasyon büyümede DB maliyeti yaratabilir

Her /sync/revisions isteği AuditLog üzerinde groupBy/count/max sorguluyor. Ön plandaki gerçek API istemcisinde istek ve yenileme tamamlandıktan 3 saniye sonra tekrar edilir; arka plan ve mock istemciler sayılmaz. N istemci için yaklaşık $N/(3+\text{işlem süresi})$ istek/s; 1.000 açık istemcide düşük gecikmeyle 333/s düzeyine yaklaşabilir. Bu kapasite ölçümü değil trafik hesabıdır. Audit kayıtları büyüdükçe maliyet ölçülmeli.

İşletmeye etkisi: Kullanıcı ve audit kaydı büyüdükçe ortak DB sorgusu gecikmeye ve gereksiz maliyete dönüşebilir; mevcut kapasite ölçülmedi.

Yapiyı koruyan çözüm: Önce staging ölçümü; alan revizyonunu güvenli kısa cache veya transaction ile güncellenen sayaç tablosuyla sun; mobil foreground davranışını koru. Gerekirse daha sonra push/SSE, ilk adımda mimariyi değiştirme.

Kabul kontrolü: Hedef eşzamanlı kullanıcı sayısında p 95/p 99, DB CPU ve sorgu planı kaydı; panel değişikliği görünme SLA'sı korunmalı.

Kanıt: B/features/sync/sync.service.ts:40 · B/features/sync/sync.routes.ts:6 · M/core/sync/revision_sync.dart:9 · M/core/sync/app_data_sync.dart:22

OPS-04 | P3 / DÜŞÜK | KOD VE BELGE KARŞILAŞTIRMASI

Operasyon belgeleri güncel davranışla çelişiyor

Yol haritası backend henüz yapılacak ve veriler mock diyor; backend ve API repo içinde var. Kerzz belgesi eski DDPAY|telefon|zaman formatını hâlâ anlatıyor, son bölümler yeni sunucu token akışını tarif ediyor. README release komutları production API/sağlayıcı doğrulamasını belirtmiyor.

İşletmeye etkisi: Kurulum ve yayın sırasında yanlış varsayımla test davranışını canlıya taşıma veya operasyon ekibine eksik bilgi verme riski.

Yapiyı koruyan çözüm: Tek güncel yayın rehberi ve canlı/test özellik matrisi oluştur; eski notları tarihli arşive taşı; iş kurallarını yönetici onaylı tek metne bağla.

Kabul kontrolü: Yeni bir geliştirici test/canlı sınırlarını, ödeme/POS/SMS durumunu ve güvenli release adımlarını tahmin yapmadan okuyabilmeli.

Kanıt: docs/ROADMAP.md:5 · docs/ROADMAP.md:33 · docs/KERZZ_POS_ENTTEGRASYON.md:30 · README.md:62

Paket taramasını doğru okumak

02.10.2026 tarihli npm audit çıktısı. Hiçbir paket güncellenmedi; audit fix veya otomatik sürüm düşürme uygulanmadı.



7 paket

Backend üretim ağacı: 4 high / 3 moderate.



12 paket

Backend geliştirme dahil: 6 high / 6 moderate.



0 bulgu

Admin üretim ve tam ağacı: Registry taramasında.

Bileşen / zincir	Kurulu sürüm	Değerlendirme
Prisma -> @prisma/config -> deepmerge-ts	6.19.3 / 7.1.5	Tek kök duyuru üst paketlere de yansıyor. CLI/config erişimi değerlendirilmeden canlı exploit denemez. [S6]
ExcelJS -> archiver -> brace-expansion	4.4.0 / 1.1.18 ve 2.1.4	Denetimsiz glob girdisinde hizmet engelleme duyuruları var. İncelenen export akışında dışarıdan glob yolu gösterilmedi. [S5]
Express -> qs	5.2.1 / 6.15.3	Parser duyuruları var. Uygulamanın JSON/query kullanımında saldırı yolunun erişilebilirliği ayrıca incelenmeli. [S7]
ExcelJS -> uuid	4.4.0 / 8.3.2	Belirli UUID buffer kullanımlarıyla ilgili duyuru; sadece paket varlığından para/veri açığı çıkarılmaz.
Geliştirme araçları	Vitest, sharp, postcss, nanoid	Tam taramada ek bulgular var. Build/test işleyişi ve girdileri ayrı değerlendirilir; hepsi mobil runtime'a taşınmaz.

Sayılar “7 ayrı uygulama açığı” demek değil

npm audit etkilenen paket düğümlerini ve üst bağımlılıkları sayar. Aynı duyuru birkaç pakette tekrar görünebilir. Admin’de 0 sonuç olması da kod mantığı veya yetkilendirme açısından sorunsuz olduğu anlamına gelmez.

Öneri: kilit dosyasına bağlı envanter, desteklenen yamalar, geçişli bağımlılık erişilebilirliği ve kontrollü regresyon. Prisma/ExcelJS için aracın önerdiği majör veya eski sürüme geçişi körlemesine uygulamayın.

Arayüzdeki vaat, arkadaki kontrol

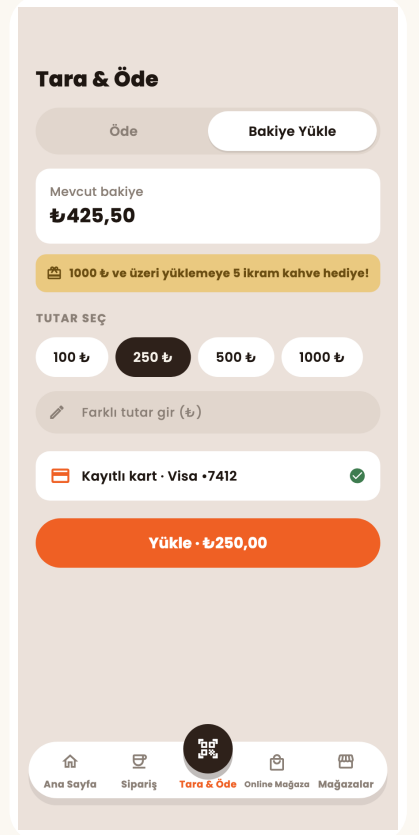
Ekranlar akışı anlaşılır kılıyor. Üretim kalitesi, bu ekranların hata ve bekleme durumlarında da doğruyu söylemesini gerektiriyor.



FİYAT ONAYI



QR GEÇERLİLİĞİ



ÖDEME SONUCU

Arayüz referansları: 30.09.2026 tarihli mevcut uygulama demo çekimleri. Örnek kullanıcı ve tutarlar içerir; gerçek işletme sonuçları değildir. Bulgular güncel d3cfc34 kodundan doğrulandı.

Müşteri ne görüyor?	Güvenilir davranış nasıl olmalı?
"Sepete ekle / Öde" tutarı	Şube ve opsiyon fiyatı sunucuyla aynı olmalı. Değiştirse para düşmeden tekrar onay alınmalı. MOB-02
60 saniyelik QR sayacı	Gerçek expiresAt esas alınmalı; bağlantı kopunca eski QR yeniymiş gibi gösterilmemeli. MOB-05
"Yüklendi" başarı mesajı	HTTP 200 yeterli değil. Ödeme sağlayıcısının doğrulanmış succeeded durumu beklenmeli. BE-01 / MOB-03

Panelde güvenilir operasyon

Güzel görünen finans ekranı, doğru kapsam ve eksiksiz kayıt gösterdiğinde yönetim kararına güvenilir veri sağlar.

Dosso Dossi
Yönetim Paneli

- Panel
- Siparişler
- Menü
- Şubeler
- Kampanyalar
- Müşteriler
- Finans**
- POS İzleme
- Yönetim

sunum@example.test
Super Yönetici
Çıkış yap

Finans

Cüzdan defteri, yüklemeler, QR tahsilatları ve mutabakat

Dışa aktar

Cüzdan defteri
Yüklemeler
QR tahsilatları
Mutabakat

Tüm tipler
Sipariş ödemesi: -₺190 (1)
Yükleme: ₺1.000 (1)
Hediye gönderimi: -₺100 (1)
QR ödemesi: -₺250 (1)
Hediye alımı: ₺100 (1)
İade: ₺190 (1)

TARİH	TİP	MÜŞTERİ	AÇIKLAMA	TUTAR	SONRAKİ BAKİYE
30.09.2026 16:10	Sipariş ödemesi	Örnek Müşteri 01 5... .. 01	Sipariş DD-2041	-₺190	₺810
30.09.2026 16:09	Yükleme	Örnek Müşteri 02 5... .. 02	Örnek yükleme — ödeme simülasyonu	₺1.000	₺1.000
30.09.2026 15:08	Hediye gönderimi	Örnek Müşteri 03 5... .. 03	Örnek hediye gönderimi	-₺100	₺540
30.09.2026 15:07	QR ödemesi	Örnek Müşteri 04 5... .. 04	Örnek QR tahsilatı	-₺250	₺275
30.09.2026 14:06	Hediye alımı	Örnek Müşteri 05 5... .. 05	Örnek hediye bakiye	₺100	₺350
30.09.2026 14:05	İade	Örnek Müşteri 06 5... .. 06	Örnek sipariş iadesi	₺190	₺625

Mevcut React panelinin 30.09.2026 örnek verili görüntüsü. Gerçek ciro, müşteri veya finansal sonuç değildir.

Müdürün görmesi gereken dört garanti

1. Sadece yetkili olduğu veri.
2. Kuruşu gizlenmeyen doğru tutar.
3. Ekrandaki filtreyle aynı kapsamda, eksiksiz dışa aktarım.
4. İptal/iade ve ödeme kayıtlarının aynı siparişe izlenebilir bağı.

Bu güvenceler ADM-02, ADM-08/09/14 ve BE-17 bulgularıyla doğrudan ilişkili. Panelin ana yapısı korunarak ortak filtre üreticisi, doğru para formatı ve kayıt referanslarıyla düzeltilebilir.

Ek notlar ve doğrulanacak riskler

Aőağıdakiler ana bulgulara ek kontrollerdir. Statik olasılıkları, gerekleőmiő aık gibi deęerlendirmeyin.

ADM-N 01 / P 3 – Müőteri 360 sipariő rozeti NaN gösterebilir

CustomerDetail extends CustomerRow ve UI data.orderCount biçimliyor; customerDetail DTO'su orderCount döndürmüyor. Ortak runtime őema/kontrat testi yok. DTO'ya gerek total count eklenmeli veya rozet kaldırılmalı.

dosso-dossi-admin/src/features/customers/CustomersPage.tsx:32 ·

dosso-dossi-admin/src/features/customers/CustomersPage.tsx:227 ·

dosso-dossi-backend/src/features/admin/customers.service.ts:128

ADM-N 02 / P 2 – Dağıtılan ikram KPI'sı adet yerine olay sayıyor

5 ikram veren TOPUP_BONUS tek LoyaltyEvent üretiyor; freeDrinksGranted count(events) olduęundan 1 ikram gibi raporlanır. Olayın nicelięi veya paymentIntent.bonusDrinks toplamı kullanılmalı.

dosso-dossi-backend/src/features/admin/dashboard.service.ts:66 ·

dosso-dossi-backend/src/features/wallet/payments/topup.service.ts:137

ADM-N 03 / P 3 – İzleyiciye birok yazma eylemi hâlâ gösteriliyor

Backend write RBAC oęunlukla doęru 403 veriyor; UI eylemleri role göre gizlemiyor. Bazı mutation onError'ları yok (OptionsTab, StatusButton, a/kapa). Yetki hatası sessiz kalabilir. Bu bir backend yetki aőımı deęil.

dosso-dossi-admin/src/features/menu/MenuPage.tsx:158 · dosso-dossi-admin/src/features/customers/CustomersPage.tsx:231 ·

dosso-dossi-admin/src/features/orders/OrdersPage.tsx:321

ADM-N 04 / P 2 – Admin token'ları localStorage'da; XSS halinde uzun ömürlü yenileme token'ı okunabilir

Koőullu sertleőtirme bulgusu: doęrudan XSS sink saptanmadı; React metin kaıőları korunuyor, dangerouslySetInnerHTML/eval yok. Refresh token12saat ve JavaScript erişilebilir. Üretim ön yüz host'unun CSP/HTTPS başlıkları doğrulanmadı. HttpOnly Secure SameSite cookie yenileme ve memory access yaklaőımı planlanmalı.

dosso-dossi-admin/src/api/client.ts:28 · dosso-dossi-backend/src/features/admin/admin-auth.service.ts:9

Ek notlar / devam

ADM-N 05 / P 2 – Son süper yönetici koruması paralel işlemlerde yarışabilir

Olası:2 aktif süper yönetici eşzamanlı düşürülürken her transaction others>0 görebilir; satır/ortak kilit veya serializable yok. Gerçek DB üzerinde denenmedi. Admin kilitlenme riskini teste al.

dosso-dossi-backend/src/features/admin/admins.service.ts:76

ADM-N 06 / P 2 – Çok sekmeli refresh rotasyonu tek uçuş korumasını paylaşmıyor

Olası: refreshing değişkeni yalnız aynı sekmede ortak; iki sekme aynı localStorage refresh token ile rotasyon yaparsa reuse tespiti tüm refreshleri kapatabilir. Tarayıcı çok-sekme testi yapılmadı.

BroadcastChannel/Web Locks veya sunucu kısa yarış toleransı değerlendirilmeli.

dosso-dossi-admin/src/api/client.ts:52 · dosso-dossi-backend/src/features/admin/admin-auth.service.ts:100

Mevcut yapıyı bozmadan yol haritası

Öncelik yeni ekran eklemek değil; para, kimlik ve durum akışlarını güvenilir hale getirmek.

Aşama	Yapılacak iş	Çıkış ölçütü
A / Yayın kilidi	Dev ödeme/SMS/POS üretim başlangıcında reddedilsin. Üretim API adresi, release imzası ve backend start yolu düzelsin.	Yanlış yapılandırma ile canlı sürüm açılmaz. Demo davranışı development/test'te korunur.
B / Para ve haklar	İptal/iade ortak servisi, atomik sadakat, kuruş politikası, POST idempotency, blokaj ve onaylanan fiyat sözleşmesi.	Paralel/tekrarlı/yanıtı kayıp tüm senaryolar tek doğru finansal sonuç verir.
C / Erişim ve panel	Şube/rol matrisi, session cache ve iptal, doğru aktif pano, ayar doğrulama, eksiksiz export ve fiyat koruma.	İki şubeli iki rollü testler ve muhasebe örnekleri aynı gerçeği gösterir.
D / Gerçek entegrasyon	Ödeme sandbox+3DS, Kerzz teslim/iptal, SMS teslimi, push, mobil ağ/QR/oturum hataları.	Sağlayıcı onaylı uçtan uca senaryolar ve arıza/tekrar testleri geçer.
E / Kontrollü pilot	Gerçek cihaz release, veri/gizlilik metinleri, yedek dönüşü, izleme/alarm, sınırlı şube ve aşamalı dağıtım.	Gözlem süresinde mutabakat farkı, kritik hata ve kayıp sipariş yok; geri alma provası tamam.

Takvim konusunda doğru beklenti

Bu rapor bir teslim tarihi tahmini değildir. Banka, Kerzz, SMS ve mağaza erişimleri süreyi belirler. Önce sağlayıcı ve iş kuralı kararları netleşmeli; her aşama kanıtı tamamlandıncaya sonraki adıma geçilmeli.

Değişiklik güvenliği planı

Aşağıdaki plan öneridir. Denetim sırasında bu değişiklikler uygulanmadı.

1. Mevcut çalışan sürümü sabitle

d3cfc34 referansı ve mevcut tasarımlar korunur. Her düzeltme küçük bir dal/PR içinde, tek iş kuralına odaklanır. Eski sürümün kabul edilen davranışları önce kayıt altına alınır.

2. Önce sorunu yakalayan test

Bu rapordaki kusur problemleri doğru beklenen sonucu sınavan regresyon testlerine çevrilir. Para, hak, kayıt sayısı, rol ve görünür durum birlikte kontrol edilir. UI kodunu birebir tekrar eden yüzeysel testlerle yetinilmez.

3. Geriye uyumlu sözleşme ve veri değişimi

Yeni idempotency/fiyat teklifi alanları sürümlü ve aşamalı eklenir. Önce genişlet, sonra doldur/doğrula, en son zorunlu kıl. Mevcut cüzdan, hediye ve birikmiş damgalar topluca sıfırlanmaz.

4. Test ortamında hata provası

Ağ kesintisi, yavaş yanıt, iki cihaz/sekme, iki paralel iptal ve sağlayıcı kesintisi staging'de denenir. Gerçek geliştirme DB'sini silen/resetleyen test kurulumları kullanılmaz.

5. Küçük pilot, gözlem ve geri alma

Özellik bayrağı veya sınırlı şube/kullanıcı grubuyla açılır. Sadece kod geri almak, yanlış finansal kaydı düzeltmez; gerekiyorsa izlenebilir telafi hareketi yapılır. Geri alma ve veri kurtarma prosedürü önceden prova edilir.

Yayın onayı için kontrol listesi

Bunlar tamamlandı işareti değil; yayın sorumlusunun kanıt isteyeceği açık maddelerdir.

Kapı	Kanıt / başarı koşulu	Sorumlu rol
Gerçek ödeme	Sandbox başarılı/red/pending/3DS/cancel; imzalı callback + sağlayıcı doğrulaması; aynı ödeme tek kredi. BE-01, MOB-03	Backend + mobil + ödeme firması
Finansal tutarlılık	BE-05..12 ve BE-14 kusurları doğru sonuca döner; defter ile bakiye/haklar eşleşir.	Backend + QA
Fiyat onayı	Şube/opsiyon değişince para düşmeden yeni toplam onayı alınır. MOB-02, BE-16	Mobil + backend
Rol / hesap güvenliği	Şube dışı veri403; eski hesap cache'i görünmez; bloke hesap harcayamaz; iptal edilmiş access token reddedilir.	Backend + admin + QA
Gerçek şube operasyonu	POS teslimi gerçekten olur; aktif sipariş kaybolmaz; iptal/iade ve tekrar kuyruğu sonuç verir.	Şube müdürü + Kerzz + QA
Mobil release	İmzalı Android/iOS paket, gerçek cihaz, HTTPS API/medya/harita, offline/arka plan/QR ve küçük ekran kontrolü. [S4]	Mobil + release sorumlusu
Veri ve mağaza hazırlığı	Onaylı gizlilik metni; uygulamada hesap silmeyi başlatma akışı; saklama/silme ayrımı ve mağaza beyanları. [S8]	Ürün + hukuk/veri sorumlusu + mobil
Operasyonel kurtarma	Şifreli DB+medya yedeği, ayrı ortamda restore, alarm kanıtı, erişim kaydı, hedef yük testi ve geri alma.	Altyapı + backend

Apple, hesap oluşturmaya destekleyen App Store uygulamalarında uygulama içinden silme başlatılmasını ister. Yalnız çıkış veya hesabı geçici kapatma bunun yerine geçmez. Bu teknik yayın kontrolüdür; hangi finansal verinin ne kadar tutulacağı ayrıca onaylanmalıdır. [S8]

Regresyon matrisi

Her düzeltme sonrası ilgili satırlar çalıştırılmalı; tüm sistemi gereksiz yere yeniden tasarlamak gerekmiyor.

Alan	Mutlaka kapsanacak örnekler	Beklenen değişmez
Oturum	401 -> 200, 401 -> 401/503; refresh offline; çıkış sırasında istek; iki admin sekmesi.	İstek asılı kalmaz; hesaplar arası veri karışmaz; geçici ağ hatası kimliği yok etmez.
Sipariş / fiyat	Yeni opsiyon/şube fiyatı, kapalı ürün, bilinmeyen opsiyon, boş şube, cevap kaybı.	Onaylanan doğru tutar; tek kullanıcı niyeti tek sipariş; açık hata.
Para / ikram	10 paralel iptal; tek hakla 10 sipariş; iki ilk yükleme; kuruş altı tutar; yetersiz bakiye.	Para/hak korunumu; negatif bakiye/hak yok; tek bonus ve tek iade.
POS / ödeme	İmza bozulması, zaman aşımı, aynı olay tekrarı, A-fail/B-success yarışı, pending/3DS.	Sadece doğrulanmış sonuç etki yaratır; eski deneme başarıyı geri alamaz.
Admin	B1/B2 rol, hesap değiştirme, eski aktif sipariş, yanlış ayar, ürün aç-kapa.	Yetki dışı veri yok; bekleyen iş görünür; değişmeyen alan korunur.
Raporlar	275+ hareket, filtreli CSV/XLSX, =1+1 isim, 0,01 ve 425,50 TL, iade detayı.	Tam kapsam; düz metin; kuruş ve kayıt referansı korunur.
Mobil görünüm	320×568/375×667, klavye, büyük yazı, ekran okuyucu, 90 sn arka plan.	Taşma/erişilemeyen kontrol/eski QR yok.
Sürüm / kurtarma	Temiz build+start, yanlış config reddi, migration, yedek geri dönüş, kontrollü rollback.	Aynı artifact tekrarlanabilir; veri korunur; alarm gerçekten ulaşır.

Kabul ölçümleri staging ve test hesaplarında tutulmalı. Test raporu, kullanılan commit, sağlayıcı sandbox kimliği ve ilgili log korelasyonu ile eşleştirilmeli; OTP veya gizli anahtar kanıt dosyalarına yazılmamalı.

Güvenilirlikten sonra en iyi kazanımlar

Ana yapıyı koruyarak kullanıcıya ve müdüre doğrudan değer katabilecek işler.

İyileştirme	Faydası	Mevcut yapıya uyarlama
Tek kampanya kuralı kaynağı	Afiş, SSS, bonus ve damga aynı şeyi söyler.	Yapılandırılmış API alanları; mevcut tasarımlar aynı modelden beslenir.
Gelen hediyeler ve durumları	Kullanıcı ne kazandığını ve nasıl kullanacağını net görür.	Hediye repo/controller üzerine alıcı görünümü; genel ikram mı ürün hakkı mı kararı önce verilir.
Hazır sipariş bildirimi	Müşteri bekleme ekranına bağlı kalmaz; şube teslimi kolaylaşır.	Mevcut durum olayına push outbox, izin ve cihaz token kaydı eklenir.
Şube seçimi ve gerçek konum	Yanlış şubeye sipariş azalır; mesafe anlamlı olur.	Önce liste aksiyonu düzelir; sonra izinli GPS ve manuel seçim fallback'i.
Güvenilir müdür görünümü	Bekleyen sipariş, POS arızası ve finans farkı tek yerde görünür.	Mevcut panelde doğru aktif sorgu ve güvenilir KPI; yeni panel yazımı gerekmez.
Daha iyi erişilebilirlik	Büyük yazı/ekran okuyucu ve küçük cihazlarda rahat kullanım.	Semantics, dokunma alanı ve sliver scroll düzeni; marka görsel dili korunur.
Hızlı açılan admin	Düşük bağlantıda daha hızlı ilk ekran.	Sayfa bazlı lazy import ve grafik kodunun ayrılması; 724 kB uyarısı profil ölçümüyle ele alınır.

En yüksek getirili ilk iyileştirme

Tek bir doğru fiyat/kampanya kaynağı ve güvenilir işlem sonucu, kullanıcı şikâyetini ve müdür müdahalesini birlikte azaltır. Görsel tasarım yatırımı korunur; verinin ve işlemin davranışı güçlenir.

Bulgu dizini ve öncelikler

Tekilleştirilmiş 57 ana madde: 1 kritik, 24 yüksek, 30 orta, 2 düşük. Buna ek 6 sertleştirme/işlev notu var. Bu sayıların tamamı güvenlik açığı değildir; hata, eksik entegrasyon, statik risk ve kanıt eksikleri birlikte raporlandı.

P0: Genel yayını doğrudan engeller. **P1:** İlgili gerçek müşteri/para pilotundan önce kapanmalı. **P2:** Planlı düzeltme; gizlilik ve mağaza gibi yayın kapıları ayrıca zorunlu. **P3:** Düşük etki veya açıklık/kalite iyileştirmesi.

Tekilleştirme: BE-18 = ADM-06; BE-19 = ADM-05; BE-22 = ADM-03; MOB-04, BE-12 altında birlikte işlendi. Öncelikler ilgili etkinin daha güçlü kanıtına göre gösterildi.

Kimlik	Öncelik	Kısa başlık	S.
BE-01	P0	Üretimde de gerçek tahsilat olmadan bakiye üreten ödeme sağlayıcısı seçiliyor	9
BE-02	P1	SMS sağlayıcısı geliştirme modunda sabit; OTP ve telefon loglanıyor	9
BE-03	P1	POS'a iletilmediği halde sipariş iletilmiş işaretleniyor	10
BE-04	P1	Dondurulan müşteri hesabı finansal işlemlere devam ediyor	10
BE-05	P1	POS iptal bildirimi müşteri parasını ve ikramını iade etmiyor	11
BE-06	P1	Aynı siparişe eşzamanlı panel iptali çift iade üretiyor	11
BE-07	P1	Bir ikram hakkı iki paralel siparişte harcanabiliyor	12
BE-08	P1	İlk yükleme özel bonus paralel yüklemelerde tekrar veriliyor	12
BE-09	P1	Eşzamanlı sadakat olayları damga/hak güncellemesini kaybediyor	13
BE-10	P1	Paralel manuel eksi bakiye düzeltmesi cüzdanı negatife düşürüyor	13
BE-11	P1	Kuruş altı tutarlar cüzdan, hediye ve defter arasında para tutarsızlığı oluşturuyor	14
BE-12 / MOB-04	P1	Müşteri sipariş/yükleme/hediye başlangıcında tekrar isteğine karşı idempotency yok	14
BE-13	P2	İçecek hediyesine sunucu tarafında ürün uygunluk sınırı uygulanmıyor	15
BE-14	P1	SMS hatası para düşülmüş hediye istemciye başarısız gösteriyor	15
BE-15	P2	OTP tüketimi atomik değil	16
BE-16	P2	Kapalı/bilinmeyen ürün opsiyonu siparişte ücretsiz kabul ediliyor	16
BE-17	P2	Sipariş detayı iade hareketini göstermiyor	17

Bulgu dizini / devam

Kimlik	Öncelik	Kısa başlık	S.
BE-20	P2	Rate limiter temizliği yeni anahtar akışında atlanıyor; OTP gönderimi IP kotasına sahip değil	17
BE-21	P2	Üretim secret doğrulaması zayıf müşteri JWT anahtarını kabul edebilir	18
BE-23	P2	Başarısız POS denemesinin geç hata kaydı başarılı tekrarın durumunu geri bozabilir	18
BE-24	P1	npm start betiği derlenen giriş dosyasının yanlış yoluna işaret ediyor	19
ADM-01	P1	Hesap değiştirildiğinde önceki yöneticinin verileri panelde kalıyor	20
ADM-02	P1	Şube müdürünün CRM, finans ve POS okumaları şubeyle sınırlanmıyor	20
ADM-03	P1	Admin şifre sıfırlama ve çıkış işlemi mevcut access token'ı iptal etmiyor	21
ADM-04	P1	Canlı sipariş panosu eski aktif siparişleri gizleyebiliyor	21
ADM-05	P1	Para ve sadakat ayarları yanlış tip veya aralıkla kaydedilebiliyor	22
ADM-06	P2	Paneldeki damga hedefi ayarı uygulama kuralını değiştirmiyor	22
ADM-07	P2	CSV dışa aktarımları kullanıcı metnini formül olarak açtırabiliyor	23
ADM-08	P2	Cüzdan CSV raporu ilk 200 kayıtla sessizce kesiliyor	23
ADM-09	P2	Sipariş Excel'i ekrandaki arama filtresini yok sayıyor	24
ADM-10	P2	Şube ürün müsaitliği değişikliği özel fiyatı siliyor	24
ADM-11	P2	POS yeniden kuyruğa alma düğmesi olayı kendisi yeniden işlemiyor	25
ADM-12	P2	Panel ürün görselini değiştirince grid fotoğrafı eski kalabiliyor	25
ADM-13	P2	CRM harcama sıralaması tüm müşteriler yerine mevcut sayfayı sıralıyor	26
ADM-14	P2	Finans tablolarında kuruluşlar yuvarlanarak gizleniyor	26
MOB-01	P1	401 sonrası başarısız yeniden deneme ağ kuyruğunu kilitliyor	27
MOB-02	P1	Onay ekranındaki fiyat ile gerçek tahsilat ayrışabiliyor	27
MOB-03	P1	Gerçek ödeme için pending/3DS/kart akışı tamamlanmamış	28

Bulgu dizini / devam

Kimlik	Öncelik	Kısa başlık	S.
MOB-05	P1	Süresi dolmuş QR ödeme kodu geçerliymiş gibi gösteriliyor	28
MOB-06	P1	Android yayın imzası ve üretim adresi için koruma eksik	29
MOB-07	P2	Hesaptan çıkınca sepet ve ikram seçimi sonraki hesaba kalıyor	29
MOB-08	P2	Takip ekranı kapandıktan sonra periyodik timer oluşabiliyor	30
MOB-09	P2	Liste görünümündeki Sipariş Ver seçilen kartın şubesini kullanmıyor	30
MOB-10	P2	Müşteri verisi yenileme ve hata durumları bazı ekranlarda sessiz kalıyor	31
MOB-11	P2	Bildirim vaadi ile mobil entegrasyon ve tercih yazma davranışı ayrışıyor	31
MOB-12	P2	Kampanya görsellerindeki kurallar panel ayarlarından beslenmiyor	32
MOB-13	P2	Online Mağaza arama klavyesi dar görünümde gövdeyi taşıyor	32
MOB-14	P2	İkon işlemlerinin bir bölümünde erişilebilir ad/rol yok	33
MOB-15	P2	Şube listesi boş olduğunda sipariş akışı açıklamasız kalıyor	33
MOB-16	P2	Hazır/iptal edilmiş sipariş durumu geçmişten izlenemiyor	34
MOB-17	P2	Gizlilik ekranı taslak; hesap silme talebi için uygulama akışı yok	34
MOB-18	P3	Gösterilen mesafe ve en yakın şube gerçek kullanıcı konumu değil	35
MOB-19	P2	Token yenileme geçici ağ hatasını kalıcı oturum iptali sayıyor	35
OPS-01	P2	Backend bağımlılıklarında bilinen güvenlik duyuruları var	36
OPS-02	P1	Yayın, yedekten dönüş ve izleme kanıtları eksik	36
OPS-03	P2	3 saniyelik senkronizasyon büyümede DB maliyeti yaratabilir	37
OPS-04	P3	Operasyon belgeleri güncel davranışla çelişiyor	37

Teknik terimler, sade karşılıkları

Terim	Bu uygulamada ne demek?
Production / üretim	Gerçek müşterinin, gerçek parasının ve gerçek şube operasyonunun kullanıldığı ortam.
Idempotency / tekrar güvenliği	Aynı işlemin ağ nedeniyle tekrar gönderilmesi, ikinci kez para veya hak hareketi üretmez.
Transaction	Birbirine bağlı kayıtların ya birlikte tamamlanması ya da birlikte geri alınması. Eşzamanlı tüm yarışları otomatik çözmez.
Atomik sahiplenme	"Bu hak/iptal hâlâ kullanılabilir mi?" kontrolüyle değişikliği tek bölünmez adımda yapmak.
Webhook	Banka veya POS'un sonucu backend'e bildirmesi. İmza gerçek göndereni, iş kuralı ise doğru etkiyi doğrular.
Access / refresh token	Kısa süreli erişim bileti ve onu yenilemek için kullanılan daha uzun süreli bilet. İkisini iptal etmek farklı kontroller gerektirir.
Outbox	Para/hediye işlemiyle kaydedilen, SMS veya POS gönderimi gibi dış işi daha sonra güvenle tekrar deneten kuyruk.
Regresyon	Düzeltilmeden önce çalışan davranışın, düzeltilmeden sonra bozulması. İlgili eski testler bunu yakalamalı.
Staging / pilot	Üretime benzeyen test ortamı / sınırlı kullanıcı ve şubeyle, ölçülerek yapılan ilk gerçek kullanım.
RPO / RTO	Arızada kabul edilen en fazla veri kaybı süresi / sistemi geri getirmek için hedef süre. Yönetimce belirlenmeli.

Kanıtlar ve resmi kaynaklar

Kod bulguları yerel d3cfc34 sürümünden; dış kaynaklar önerilen kontrol ilkelerini doğrulamak için kullanıldı. Erişim tarihi: 02.10.2026.

S1 OWASP – Third Party Payment Gateway Integration

Ödeme durumu, beklenen tutar/para birimi, callback doğrulama ve tekrar güvenliği.

S2 OWASP – Business Logic Security

Sunucuda iş kuralı doğrulama, durum geçişleri ve eşzamanlılık yaklaşımı.

S3 OWASP – API Security Top 10 2023

Nesne/fonksiyon yetkilendirmesi ve hassas iş akışlarının korunması.

S4 Flutter – Build and release an Android app

Mağaza yayını için release imzalama ve artifact üretimi.

S5 GitHub Advisory – brace-expansion

GHSA-qhr7-859c-m2p7: iç içe glob gruplarında recursion/DoS duyurusu.

S6 GitHub Advisory – deepmerge-ts

GHSA-ggr8-5vv4-36mx: döngüsel nesne birleştirmede stack exhaustion.

S7 GitHub Advisory – qs

GHSA-4mjr-xmp4-gh2g: denetimsiz isBuffer girdisiyle hizmet engelleme.

S8 Apple Developer – Offering account deletion

Hesap açılan uygulamalarda uygulama içinden hesap silmeyi başlatma rehberi.

Yerel kanıt paketi: /tmp/dosso-prod-audit-20261002 altında test JSON/logları, izole yeniden üretim kodları ve dört denetim grubunun bulgu dosyaları tutuldu. Bu geçici izin kalıcı arşiv değildir. PDF, karar ve kaynak satırı referanslarını kendi içinde taşır.

Repo kökü: /Users/berkaydemir/dosso-dossi

İncelenen commit: d3cfc34cd869b83093bb60de21a83e07aae5cc55

Görsel referanslar: proje içindeki mevcut demo ekranları ve marka logosu. Gerçek müşteri/işletme verisi rapora alınmadı.

Karar özeti ve sonraki adım

Bugünkü karar

Uygulama genel yayına hazır değil. Ürün kapsamı ve tasarım yatırımı kullanılabilir durumda; ancak gerçek para, gerçek şube ve gerçek kullanıcı için henüz kapanmamış önemli riskler var.

Yapılması gereken

Önce ödeme/POS/SMS üretim ayırımı ve finansal tutarlılığı düzeltin. Sonra yetki sınırları, fiyat onayı, mobil hata yolları ve operasyon kanıtlarını tamamlayın. Her madde kendi kabul testiyle kapatılsın.

Yapıyı koruyarak ilerleyiş

Mevcut ekranlar, marka dili, repository/servis ayrımları ve doğru çalışan kontroller korunmalı. Küçük PR'lar, geriye uyumlu sözleşmeler, test ortamı ve sınırlı pilot ile ilerlemek yeterli; kapsamlı yeniden yazım önerilmiyor.

Denetimin mevcut ortama etkisi

Uygulama kaynaklarında, ortam ayarlarında veya çalışan veritabanında değişiklik yapılmadı. Ayrı denetim container'ı kaldırıldı. Mevcut uygulama/backend/admin süreçleri denetim için durdurulmadı.

Yayın onayı, “ekranlar çalışıyor” gözlemiyle değil; doğru para hareketi, doğru yetki, doğru şube işlemi ve kurtarma kanıtıyla verilmeli.